

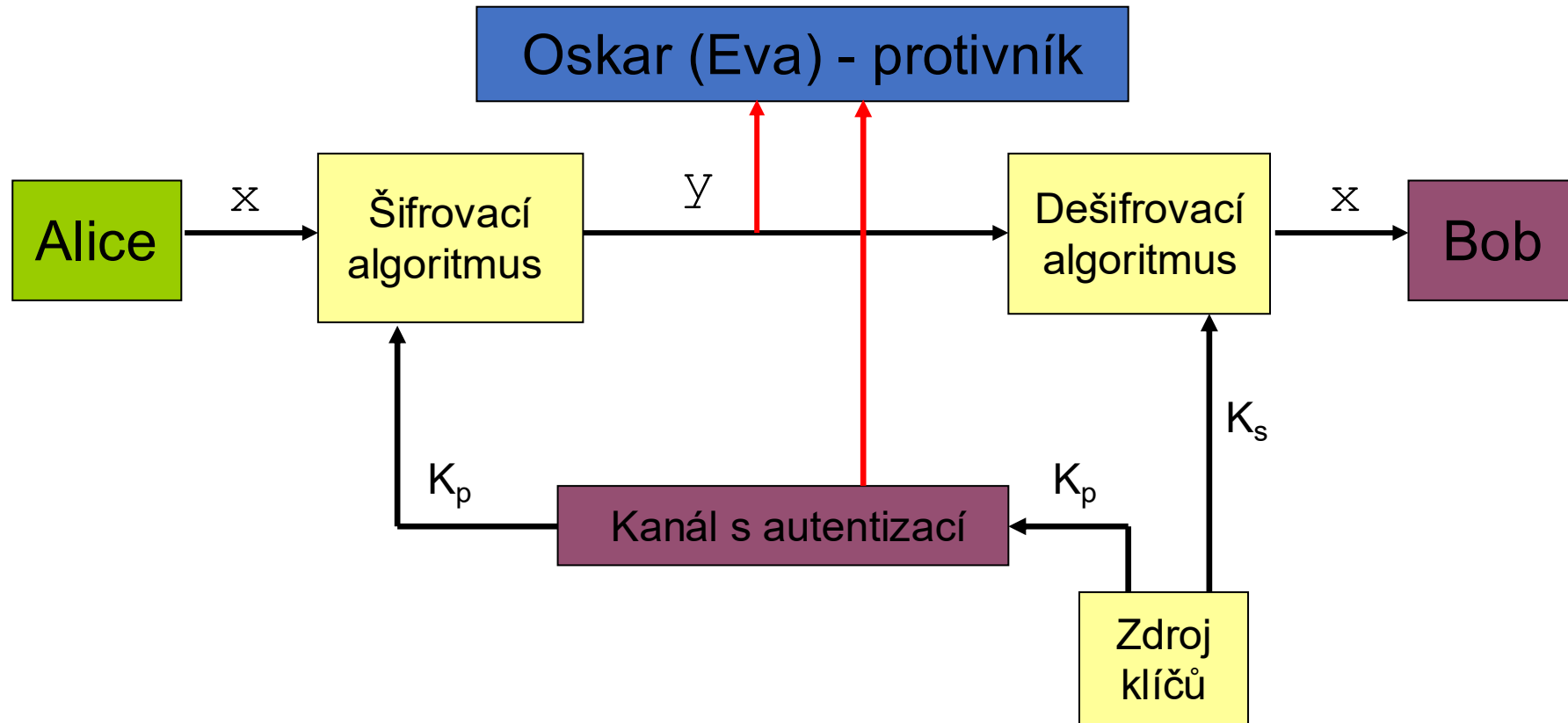
Asymetrická kryptografie

Prof. Ing. Cyril Klimeš, CSc.

Princip asymetrického zabezpečení krabice

- Bob navrhne zámek a jeho kopie distribuuje po celém světě, klíč si ponechá.
- Alice uloží tajnou zprávu do krabice, na které zaklapne Bobův zámek, a pošle ji zpět Bobovi poštou.
- Bob si vyzvedne krabici a odemkne ji svým klíčem.

Šifrovací systém s veřejným klíčem



x – **otevřený text,**
 K_p – **veřejný klíč**

y – **šifrový text,**
 K_s – **tajný (soukromý) klíč**

Požadavky

- Pro dvojici klíčů (K_p, K_s) platí, že $d_{K_s}(e_{K_p}(x)) = x$ pro každou zprávu x .
- Kanál pro přenos veřejného klíče K_p nemusí být bezpečný (tj. zajišťující důvěrnost přenášených zpráv), musí ale zajišťovat autentizaci, tj. Bob si musí být jistý, že veřejný klíč dostal skutečně od Alice.
- Generátor klíčů je obvykle na straně příjemce zprávy, tj. u Alice.
- Šifrovací a dešifrovací algoritmy musí být rychlé, zatímco dešifrování bez znalosti soukromého klíče musí být výpočetně nezvládnutelné.

Vlastnosti asymetrického šifrování

- soukromý klíč je tajemstvím pouze příjemce, nikoliv obou partnerů,
- veřejný klíč umožňuje každému zašifrovat zprávu pro příjemce,
- cenou za toto větší pohodlí je větší složitost systémů s veřejným klíčem jak po matematické stránce tak z hlediska počtu operací, které je třeba provádět.
- Systémy s veřejným klíčem jsou proto mnohem pomalejší oproti symetrickým šifrovacím systémům, jejich bezpečnost se posuzuje mnohem obtížněji.

Šifrovací algoritmus RSA

- Vygenerujeme dvě dostatečně velká prvočísla ***p*** a ***q*** (každé má délku 1024 bitů) a spočteme ***n=pq***.
- Číslo ***n*** je parametrem šifrovacího systému (šifrovací modul) a zveřejňuje se spolu s veřejným klíčem.
- Spočítá se Eulerova funkce

$$f(n) = (p-1)(q-1)$$

udává počet přirozených čísel menších než ***n***, která jsou nesoudělná s číslem ***n*** (protože ***n*** je součinem dvou prvočísel, je takových čísel právě $(p-1)(q-1)$)

Šifrovací algoritmus RSA

- Zvolíme privátní klíč e z množiny $\{1, \dots, n\}$ nesoudělný s číslem $(p-1)(q-1)$
- K veřejnému klíči e vypočteme Eulerovým algoritmem soukromý (tajný) klíč d podle vztahu

$$d \cdot e \bmod (p-1)(q-1) = d \cdot e \bmod f(n) = 1$$

- Tato rovnice má jediné řešení d
- Zakódování zprávy z se provede dle vztahu $z^e \bmod n = s$
- Dekódování zprávy se provede dle vztahu $s^d \bmod n = z$
- Korektnost šifry je dána vztahem:

$$z = s^d \bmod n = z^{de} \bmod n = z^{kf(n)+1} \bmod n = 1 \cdot z \bmod n = z$$

RSA šifra

- Dvě prvočísla p, q
- Šifrovací modul $n = p \cdot q$
- Dešifrovací exponent d nesoudělný s n
- $f(n) = (p-1) \cdot (q-1)$
- e je řešení kongurence $e \cdot d = 1 \pmod{f(n)}$
- Veřejný klíč: n, e
- Tajný klíč: n, d
- Dvě přirozená čísla jsou nesoudělná, mají-li společného dělitele pouze číslo 1

Příklad určení klíčů

- $p=7, q=13$
- $n=91, \phi(n)=6 \cdot 12=72$
- Zvolí se $d=7$ menší než 72 a nesoudělné s 72, tak aby platilo $de \equiv 1 \pmod{72}$
- $e \cdot 7 \equiv 1 \pmod{72}$, - hledáme e kdy $x \cdot 72 + y \cdot 7 = 1$
- $72 = 10 \cdot 7 + 2$ takže $2 = 72 - 7 \cdot 10$
- $7 = 3 \cdot 2 + 1$ takže $1 = 7 - 3 \cdot 2 = 7 - 3(72 - 10 \cdot 7)$ z toho $31 \cdot 7 - 3 \cdot 72 = 1$
- $e=31$
- Veřejný klíč $e=31, n=91$, šifrování $y=x^{31} \pmod{91}$
- Tajný klíč $d=7, n=91$, dešifrování $x=y^7 \pmod{91}$

Příklad šifrování a dešifrování

- $x=24$
- $y = x^{31} \bmod 91 = 24^{31} \bmod 91 = (24^{16} \bmod 91) \cdot (24^8 \bmod 91) \cdot (24^4 \bmod 91) \cdot (24^2 \bmod 91) \cdot (24^1 \bmod 91) = 81 \cdot 9 \cdot 81 \cdot 30 \cdot 24 \bmod 91 = 42515280 \bmod 91 = 80$
- $x = 80^7 \bmod 91 = (80^1 \bmod 91) \cdot (80^2 \bmod 91) \cdot (80^4 \bmod 91) = 80 \cdot 30 \cdot 81 \bmod 91 = 24$

Prolomení veřejného klíče

- Veřejný klíč je $(n, e) = (91, 31)$
- Potřebuji určit, ze kterých prvočísel se skládá n , hledám kombinace
- Od začátku prvočísla 3, 5, 7, 11,...
- Podělím číslo 91 postupně prvočísly, již při třetím kroku $91/7=13$ jsem našel prvočísla, kterým dělím beze zbytku ($7 \cdot 13 = 91$)
- Pak určím $\phi(n) = (7-1)(13-1) = 72$
- Soukromý klíč pak určím z multiplikativní inverze $31^{-1} \bmod (72)$
- $72 = 2 \cdot 31 + 10$ z toho $10 = 72 - 2 \cdot 31$
- $31 = 3 \cdot 10 + 1$ z toho $1 = 31 - 3 \cdot 10 = 31 - 3 \cdot (72 - 2 \cdot 31) = 7 \cdot 31 - 3 \cdot 72$
- $31^{-1} \bmod (72) = 7 \bmod (72)$
- Proč se to tak jednoduše podařilo? Protože byla zvolena malá prvočísla.

Máte určeny dvě prvočísla $p=5$, $q=7$, vypočtete tajný klíč e a veřejný klíč d , zašifrujte zprávu reprezentovanou číslem $x = 7$ veřejným klíčem a pak dešifrujte tajným klíčem. Uveďte postup.

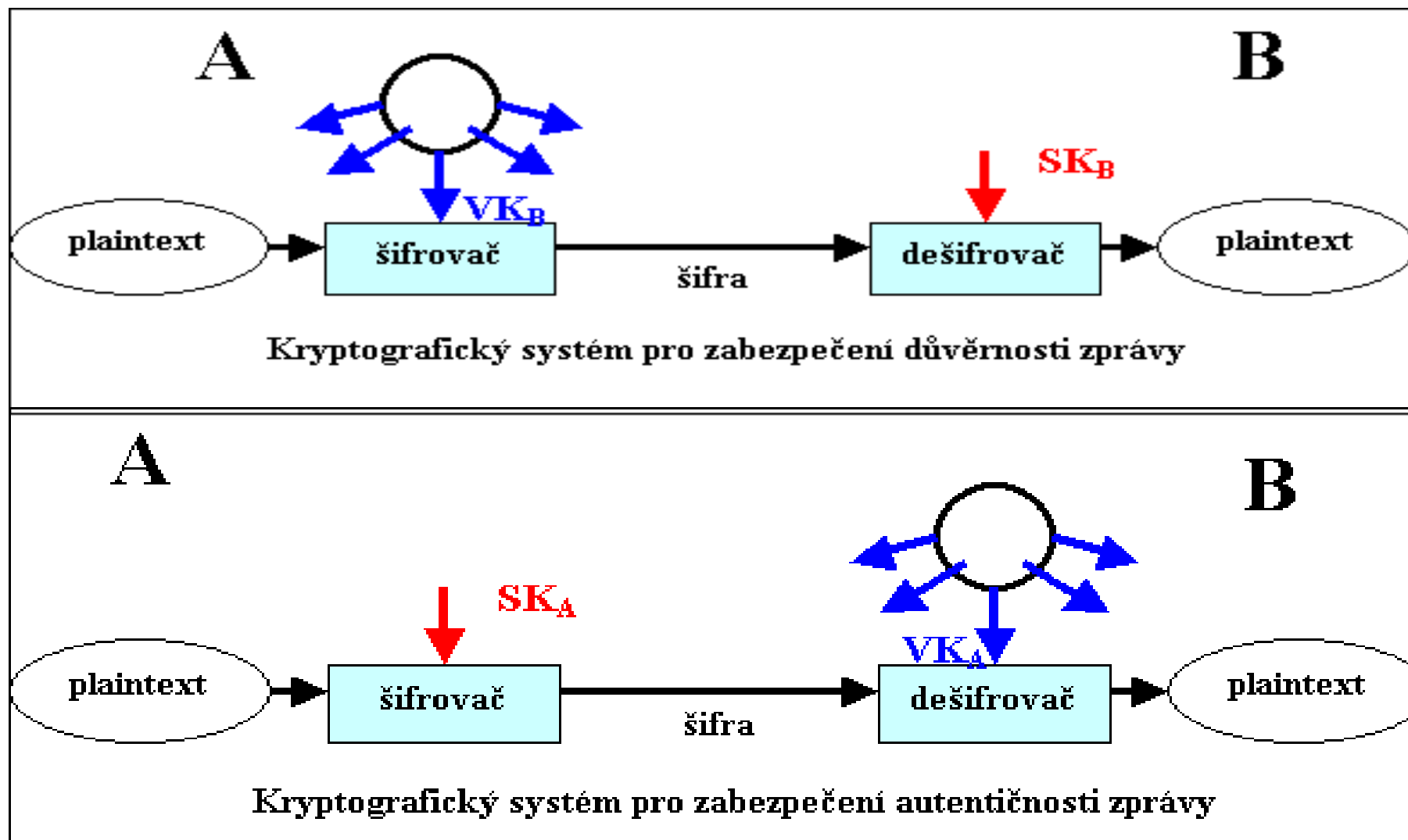
- $n=35$,
- $f(n)= 24$
- $e = 5$ (musí být menší než 24 a nesoudělný) nebo $e=7$ nebo $e=11, 13, 17, 19$
- pro $e=5$
- $24=4.5+4$ z toho $4=24-4.5$
- $5=1.4+1$ z toho $1=5-1.4= 5-1.(24-4.5)=5.5-24$ proto $d=5$
- $y=x^5 \bmod 35=7^5 \bmod 35= 7$
- $x=7^5 \bmod 35=7$

- Pro $e=7$
- $24=3 \cdot 7+3$ z toho $3=24-3 \cdot 7$
- $7=2 \cdot 3+1$ z toho $1=7-2 \cdot 3=7-2 \cdot (24-3 \cdot 7)=7 \cdot 7-2 \cdot 24$
- Takže $d=7$
- $y=7^7 \bmod 35=28$
- $x=28^7 \bmod 35=7$
- Pro $e=11$
- $24=2 \cdot 11+2$ z toho $2=24-2 \cdot 11$
- $11=5 \cdot 2+1$ z toho $1=11-5 \cdot 2=11-5(24-2 \cdot 11)=11 \cdot 11-5 \cdot 24$ proto $d=11$
- $y=7^{11} \bmod 35=28$
- $x=28^{11} \bmod 35=7$

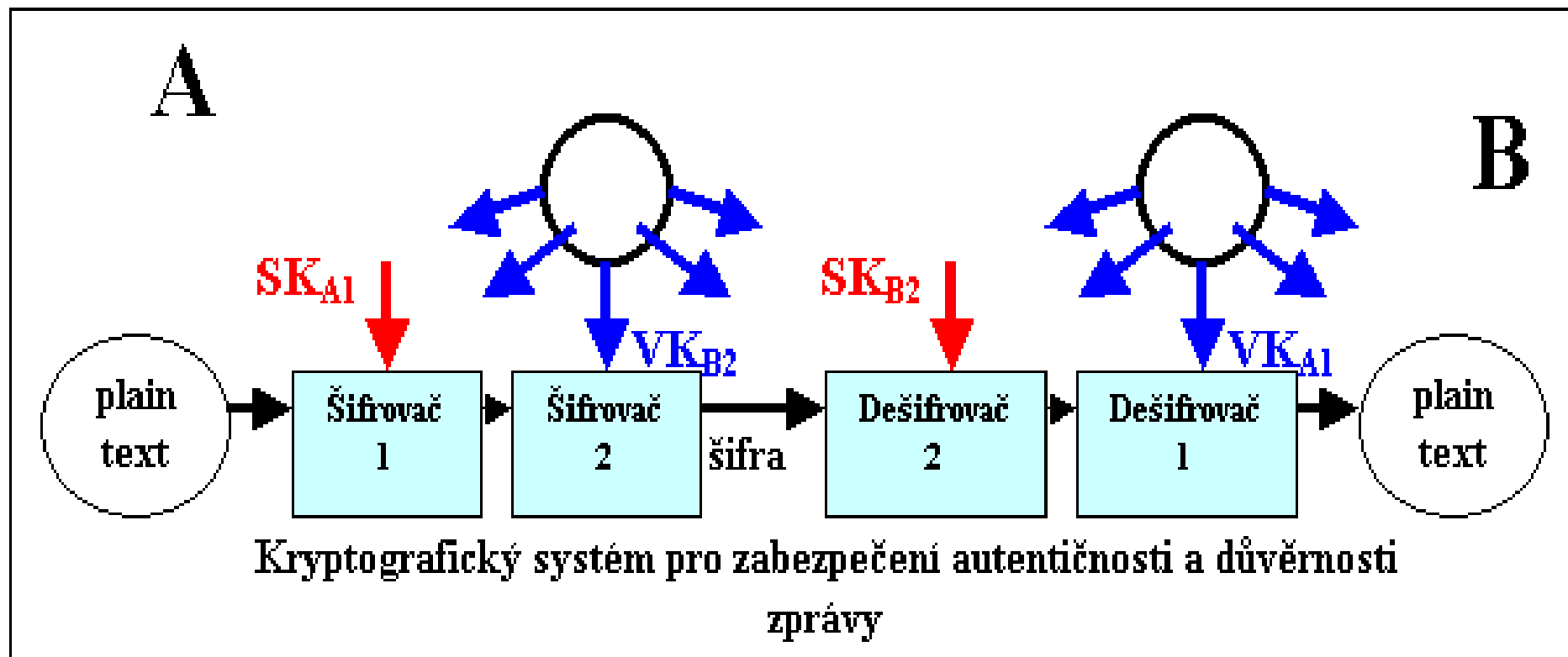
Prolomení veřejného klíče

- Veřejný klíč je $(n,e) = (35,5)$
- Potřebuji určit, ze kterých prvočísel se skládá n , hledám kombinace
- Od začátku prvočísla 3, 5, 7, 11,...
- Podělím číslo 35 postupně prvočísky, již při druhém kroku $35/5=7$ jsem našel prvočísla, kterým dělím beze zbytku ($5 \cdot 7 = 35$)
- Pak určím $\phi(n) = (5-1)(7-1) = 24$
- Soukromý klíč pak určím z multiplikativní inverze $5^{-1} \bmod (24) = 5 \bmod (24)$

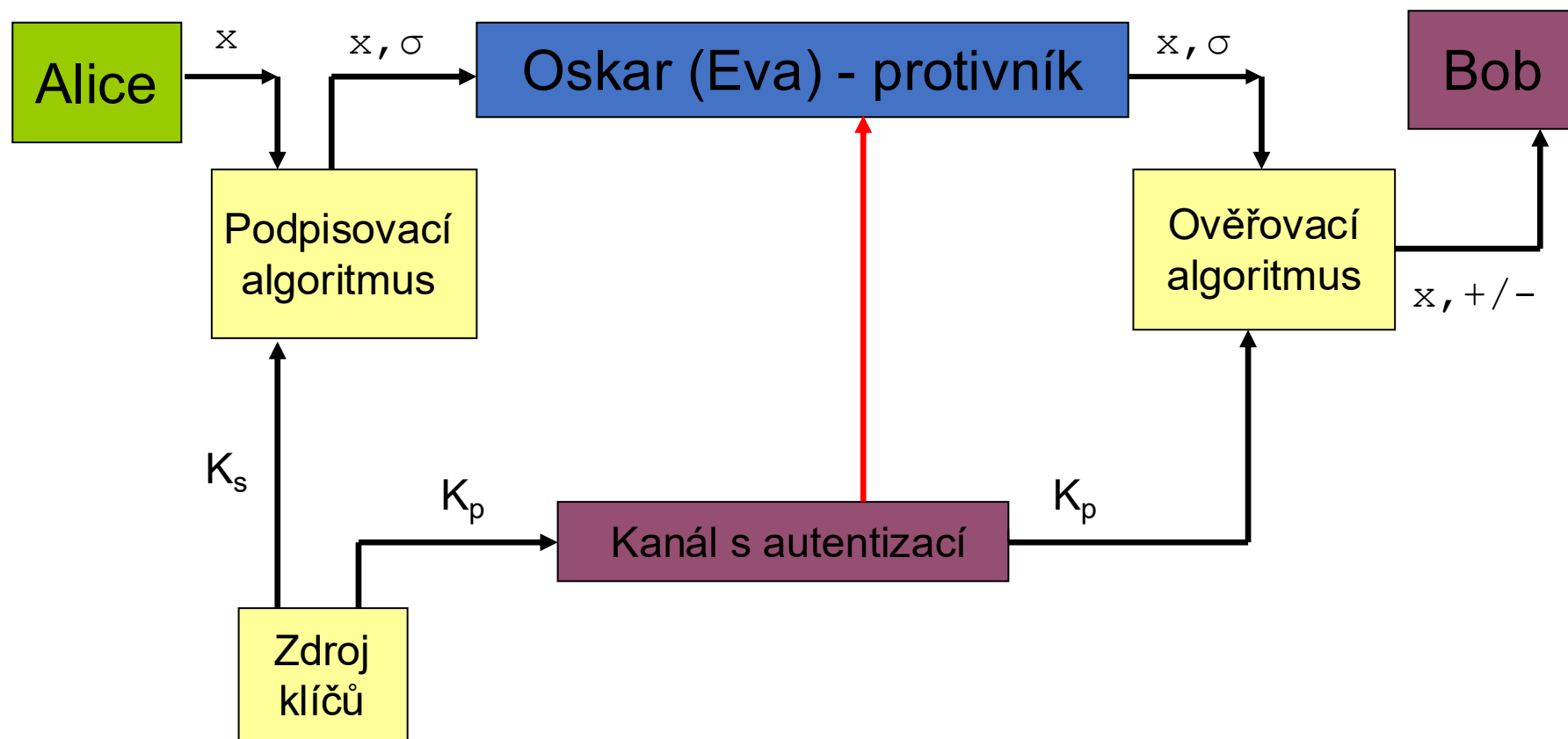
Uplatnění asymetrických algoritmů



Uplatnění asymetrických algoritmů



Digitální podpis



x – **podpisovaný text,**
 K_p – **veřejný klíč**

σ – **digitální podpis,**
 K_s – **tajný (soukromý) klíč**

Digitální podpis

- Schéma s veřejným klíčem pro digitální podpis tvoří:
 - generátor pseudonáhodných čísel,
 - podpisovací algoritmus, který ze zprávy x a tajného klíče K_s vypočítá digitální podpis σ ,
 - ověřovací algoritmus, který pro každou zprávu x , podpis σ a veřejný klíč K_p ověří správnost podpisu.
-
- Digitální podpis musí zajistit několik bezpečnostních cílů.
 - **Nezfalšovatelnost podpisu.** Pro útočníka musí být nemožné bez znalosti tajného klíče K_s vytvořit ke zprávě x platný podpis σ .
 - To musí platit i v situaci, kdy útočník má k dispozici několik platných podpisů (x_i, σ_i) , dokonce i když si může volit zprávy x_i .
 - **Nepopiratelnost podpisu.** Ten, kdo zprávu podepsal, nesmí mít později možnost svůj podpis popřít. To znamená, že autor podpisu nemůže dokázat, že podpis lze zfalšovat.

Nezfalšovatelnost podpisu

- Podvržení podpisu může mít několik podob.
- **Úplné prolomení systému** spočívá v tom, že útočník dokáže ze znalosti veřejného klíče K_p získat tajný klíč K_s .
- **Univerzální podvržení.** Na základě veřejného klíče K_p útočník dokáže vytvořit algoritmus, který vytváří platné podpisy k libovolné zprávě x .
- **Selektivní podvržení.** Na základě veřejného klíče K_p útočník dokáže vytvořit zprávu, ke které pak umí připojit platný podpis.
- **Existenční podvržení.** Na základě veřejného klíče K_p je útočník schopen vytvářet dvojice (x, σ) , kde σ je platný podpis zprávy x . Nemá ale žádnou kontrolu nad tím, jak zpráva x vypadá.

Od šifrovacího k podpisovému systému

- Šifrovací systém s veřejným klíčem můžeme snadno přeměnit v podpisový systém s veřejným klíčem tak, že použijeme dešifrovací algoritmus jako podpisovací algoritmus a šifrovací algoritmus jako ověřovací.
- Dešifrovací algoritmus totiž závisí na tajném klíči, který je známý pouze tomu, kdo podepisuje.
- Šifrovací algoritmus závisí na veřejném klíči, který je dostupný každému, podpis tedy může ověřit kdokoliv.
- V takto jednoduché podobě jde o *podpis s obnovou zprávy*.
- Podepisovanou zprávu x není nutné posílat spolu s podpisem σ , protože ji získáme z podpisu σ jako výsledek ověřovacího algoritmu.
- V případě dlouhých zpráv trvá vytvoření podpisu a jeho ověření příliš dlouho. Asymetrické šifrovací systémy jsou příliš pomalé.

Jednoduchý RSA podpis

- Použijeme-li jako výchozí šifrovací systém RSA, dostaneme *jednoduchý RSA podpis*.
- Ten trpí několika problémy, které jsou způsobené tvarem šifrovacího a dešifrovacího algoritmu u RSA.
- Tak například není odolný vůči existenčnímu podvržení.
- Každý si snadno může k libovolnému náhodně zvolenému podpisu σ vytvořit zprávu $m = \sigma^e \bmod N$, jejímž podpisem je právě σ .
- Vytvoří tak zprávu m s platným podpisem σ , nemá ale žádnou kontrolu nad podobou zprávy m .
- Stejně tak je snadné ze dvou platných podpisů (m, σ) a (m', σ') vytvořit nový platný podpis (m'', σ'') tak, že položíme

$$m'' = mm' \bmod N \quad \text{a} \quad \sigma'' = \sigma\sigma' \bmod N.$$

- Tyto bezpečnostní problémy lze odstranit použitím hašovací funkce.

System bez obnovy zprávy

- V praxi se proto používají *podpisové systémy bez obnovy zprávy*.
- Nepodepisuje se zpráva x , ale hodnota $H(x)$, kde H je nějaká hašovací funkce.
- Podepisují se tak pouze zprávy délky rovné délce hašovací funkce H .
- Podpisem je tak dvojice $(H(x), \sigma)$, kde σ je podpis textu $H(x)$.
- Podepisovaná zpráva x se posílá spolu s podpisem, není ji proto nutné obnovovat.
- *Použitá hašovací funkce musí být odolná vůči nalezení kolizí.*
- V opačném případě by bylo možné mít stejný podpis ke dvěma různým zprávám.
- Jednu by si útočník nechal podepsat a pak by podpis připojil ke druhé zprávě.
- Tím by podvrhnul podpis druhé zprávy.

ElGamalův podpis

- Je založený na ElGamalově šifrovacím systému.
- Dva veřejné parametry jsou velké prvočíslo p a kladné číslo g menší než p takové, že $g^x \bmod p$ je různé od 1 pro každé kladné $x < p-1$.
- Generátor klíče nyní vygeneruje náhodné kladné x a spočítá číslo
$$y = g^x \bmod p.$$
- Veřejný klíč je $K_p = y$.
- Tajný klíč je $K_s = x$.
- Pak se spočítá otisk $h = H(m)$ podepisované zprávy m pomocí nějaké hašovací funkce H .
- Podpis se vygeneruje tak, že se zvolí náhodné kladné číslo k menší než $p-1$ a spočítá $r = g^k \bmod p$ a $s = (h - xr)k^{-1} \bmod (p-1)$.
- Podpis zprávy h je potom dvojice $\sigma = (r, s)$.
- Ověřovací algoritmus spočívá v ověření rovnosti $y^r r^s = g^h \bmod p$.
- Pokud byl totiž podpis $\sigma = (r, s)$ správně spočítán, tak platí

$$y^r r^s = g^{xr+ks} = g^h \bmod p.$$

Dvoufaktorová autentizace s využitím RSA

- **V aplikaci se vygeneruje pár RSA klíčů, přičemž veřejný klíč se bezpečným kanálem přenese na server a privátní klíč se bezpečně uloží do telefonu.** V okamžiku, kdy se bude uživatel autentizovat, zašle server do aplikace na telefonu zabezpečeným kanálem výzvu (náhodně vygenerovaný dlouhý řetězec).
- **Uživateli se na obrazovce smartphonu objeví dotaz, zda se chce autentizovat** do aplikace (volitelně mu může být zobrazena i jeho IP adresa, geolokace, datum posledního přihlášení a další informace).
- **Pokud uživatel přihlášení odsouhlasí, dojde k podepsání výzvy jeho privátním klíčem** a zaslání zpět na server. Server použije veřejný klíč k tomu, aby ověřil, že podpis souhlasí, a v případě že je podpis vyhodnocen jako platný, je uživatel přihlášen.

Autorizace transakce v elektronickém bankovníctví

- Uživateli jsou spolu s náhodnou výzvou zaslány bezpečným kanálem i informace o požadované transakci (tyto informace dnes mnohé banky posílají spolu s mTAN v autorizační SMS).
- Uživateli se zobrazí na obrazovce detaily transakce, a pokud souhlasí s tím, co uživatel zadal v aplikaci, tak transakci potvrdí. Tím dojde k podepsání výzvy a zaslání odpovědi na server. Server pak stejně jako v předchozím případě ověří podpis a pokud je platný, je transakce realizována.
- Pokud by vám vadilo, že uživatel musí být při tomto způsobu autentizace a autorizace připojen do internetu, což může být v některých případech problém, protože ne každý má Wi-Fi nebo aktivován internet v mobilu, tak i tenhle problém lze snadno vyřešit.
- Ovšem bez použití asymetrické kryptografie, takže tím zároveň padá i hlavní výhoda tohoto řešení. Tedy že **heslo ani jeho hash není nikde uložen a tak ho nikdo nemůže zkopírovat, odchytit, prolomit a realizovat tak neoprávněnou transakci.**
- V tomto případě se může na obrazovce zobrazit např. QR kód, který se sejme pomocí kamery v mobilu. Aplikace ho zpracuje a na obrazovce zobrazí výzvu k autentizaci nebo autorizaci, ta se spojí se sdíleným tajemstvím, vytvoří se hash a ten se přetransformuje na snadno přepsatelný řetězec např. pomocí HOTP (HMAC based One Time Password Algorithm – jednorázové heslo).

Hash funkce

Jde o jednosměrnou funkci, kdy řetězec na vstupu vygeneruje vždy stejný hash, ale při znalosti hashe nelze zpětně zjistit, o jaký řetězec se jednalo. Hash tedy funguje podobně jako unikátní **otisk vstupních dat.**

Vlastnosti hashů

- 1.Hashovací funkce pro daný vstupní řetězec vygeneruje vždy stejný výstupní hash.
- 2.Hashovací funkce pro různá data vždy produkuje hash o stejné délce.
- 3.Z výstupního hashe nelze nijak získat původní vstupní data (hashovací funkce je skutečně jednosměrná).
- 4.Nelze nalézt různá vstupní data pro tentýž výstupní hash (pokud se je podaří nalézt, říká se tomu **kolize** a znamená to, že hashovací funkce není bezpečná).

Hash funkce

- Vstupní data libovolné délky jsou transformována do výstupních dat pevné délky (128, 160, 256, 512 bitů)
- Jednocestná funkce s klíčem nebo bez klíče
- Principy jednocestné funkce $y = F(x)$:
 1. pro dané x lze snadno spočítat $y = F(x)$
 2. pro dané y je výpočetně nezvládnutelné nalézt x , aby platilo $y = F(x)$
 3. pro dané x je výpočetně nezvládnutelné nalézt takové x' ($x' \neq x$), aby platilo $F(x) = F(x')$

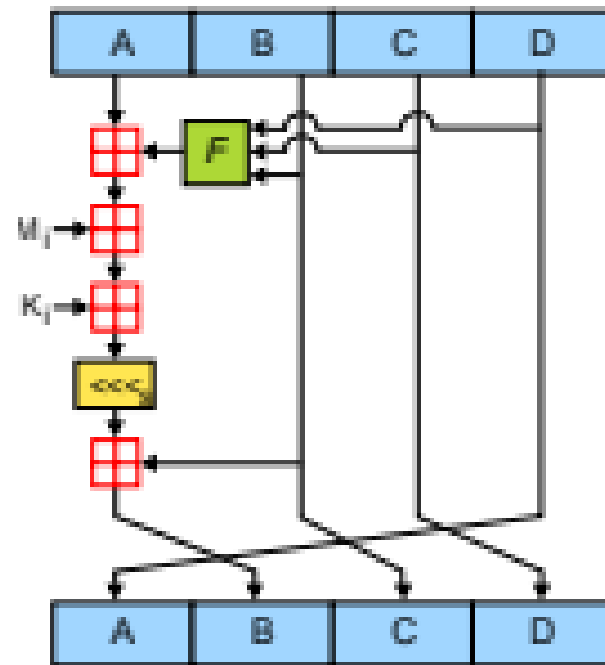
Nejznámější hashovací funkce

- **MD5** – algoritmus vytváří otisk o velikosti 32 znaků. Vznikl v roce 1991, dlouhou dobu se používal k ukládání hesel v internetových aplikacích. Od roku 1996 již není považován za dostatečně bezpečný, od roku 2004 dokonce za velmi nebezpečný, protože lze velmi rychle najít dva vstupní řetězce, pro které vytvoří shodný otisk. Proto se doporučuje tuto funkci vůbec nepoužívat.
- **SHA1** – nástupce hashovací funkce MD5, která produkuje výstup o délce 40 znaků, vznikl v roce 1995, v roce 2005 však byla nalezena jeho slabina a jeho použití pro ukládání hesel tak není dále doporučováno. Hodí se však stále pro ověřování integrity dat (zde je výhodou, že je funkce rychlá).
- **Bcrypt** – hashovací funkce založená na šifře *Blowfish*, vznikla v roce 1999. Dnes se doporučuje k ukládání hesel v aplikacích, neboť v sobě zahrnuje kryptografickou sůl a hlavně ji lze nastavit tak, že se vykonává opakovaně, tedy pomalu – a tím značně zvyšuje ochranu proti útokům hrubou silou.

Porovnání

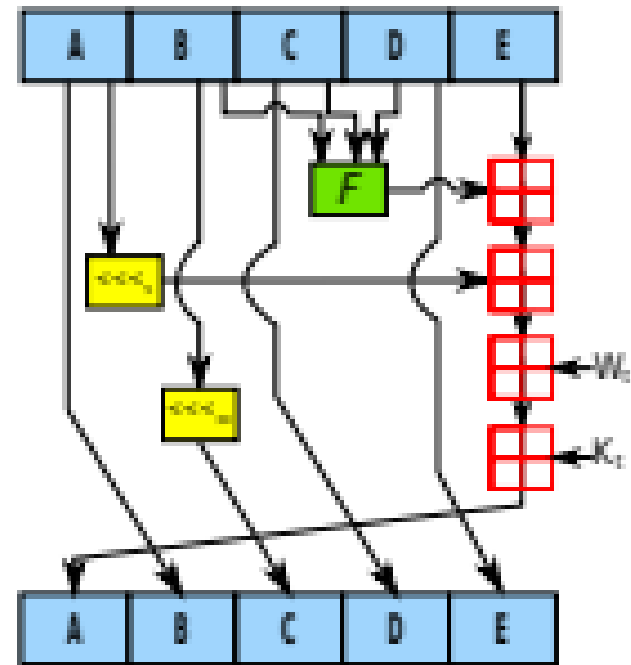
		Velikosti (v bitech)		
Algoritmus		Výstup	Vnitřní stav	Blok
SHA-2	MD5	128	128	512
	SHA-1	160	160	512
	SHA-224	224	256	512
	SHA-256	256	256	512
	SHA-384	384	512	1024
	SHA-512	512	512	1024
	SHA-512/224	224	512	1024
	SHA-512/256	256	512	1024

MD5



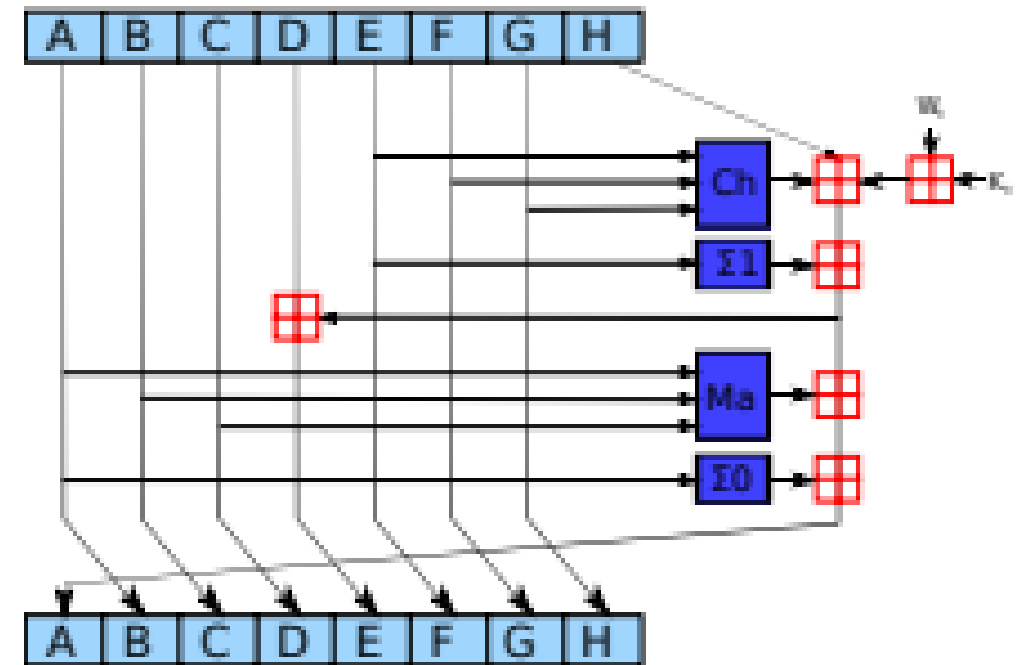
64 rund

SHA-1



80 rund

SHA-2



64 nebo 80 rund

Princip hash funkce MD5

4 registry po 32 bitech

Značení v obrázku

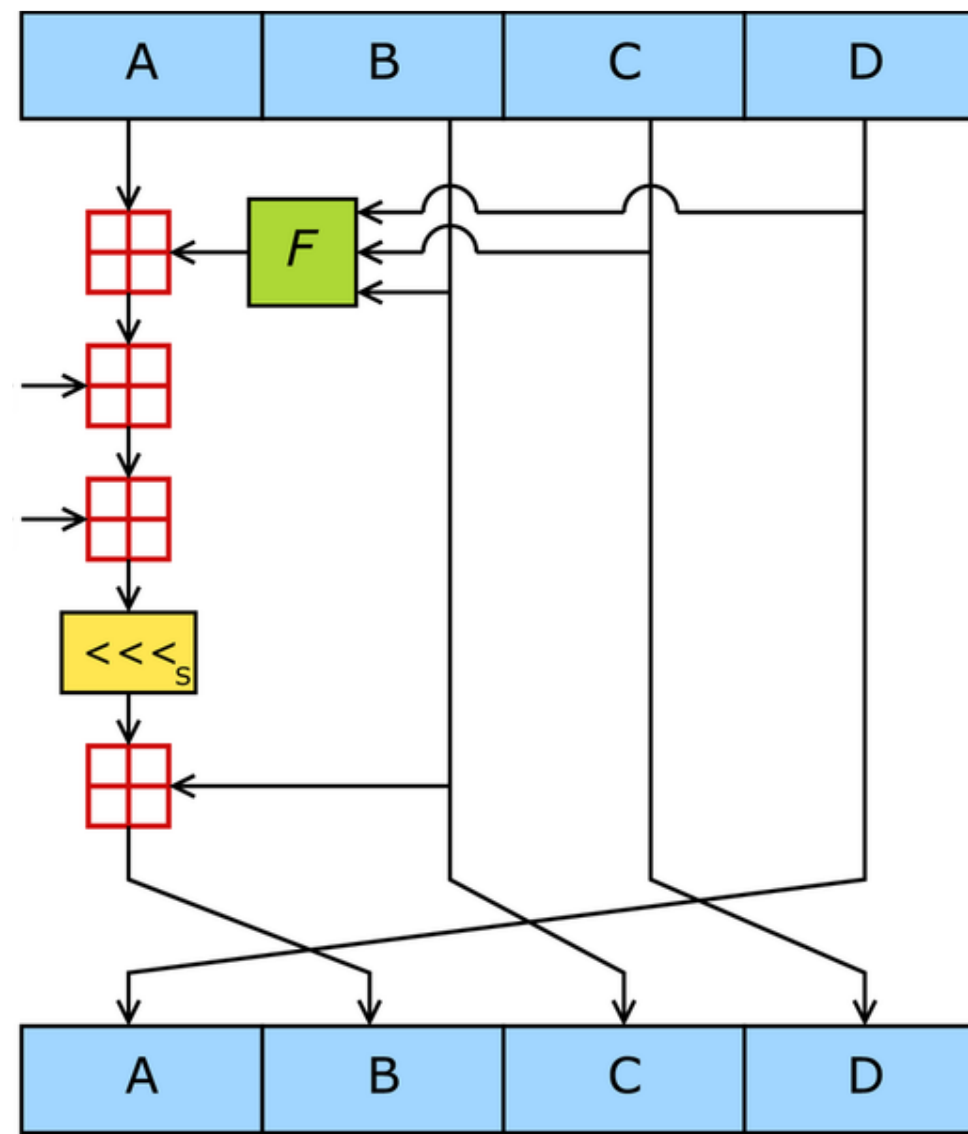
- $\lll_s$ levá bitová rotace o s míst
- $\boxplus$ součet mod 2^{32}
- A, B, C, D konstanty
- K_i další konstanta
- M_i 32b blok zprávy

Zpráva je rozdělena na bloky délky 512 b

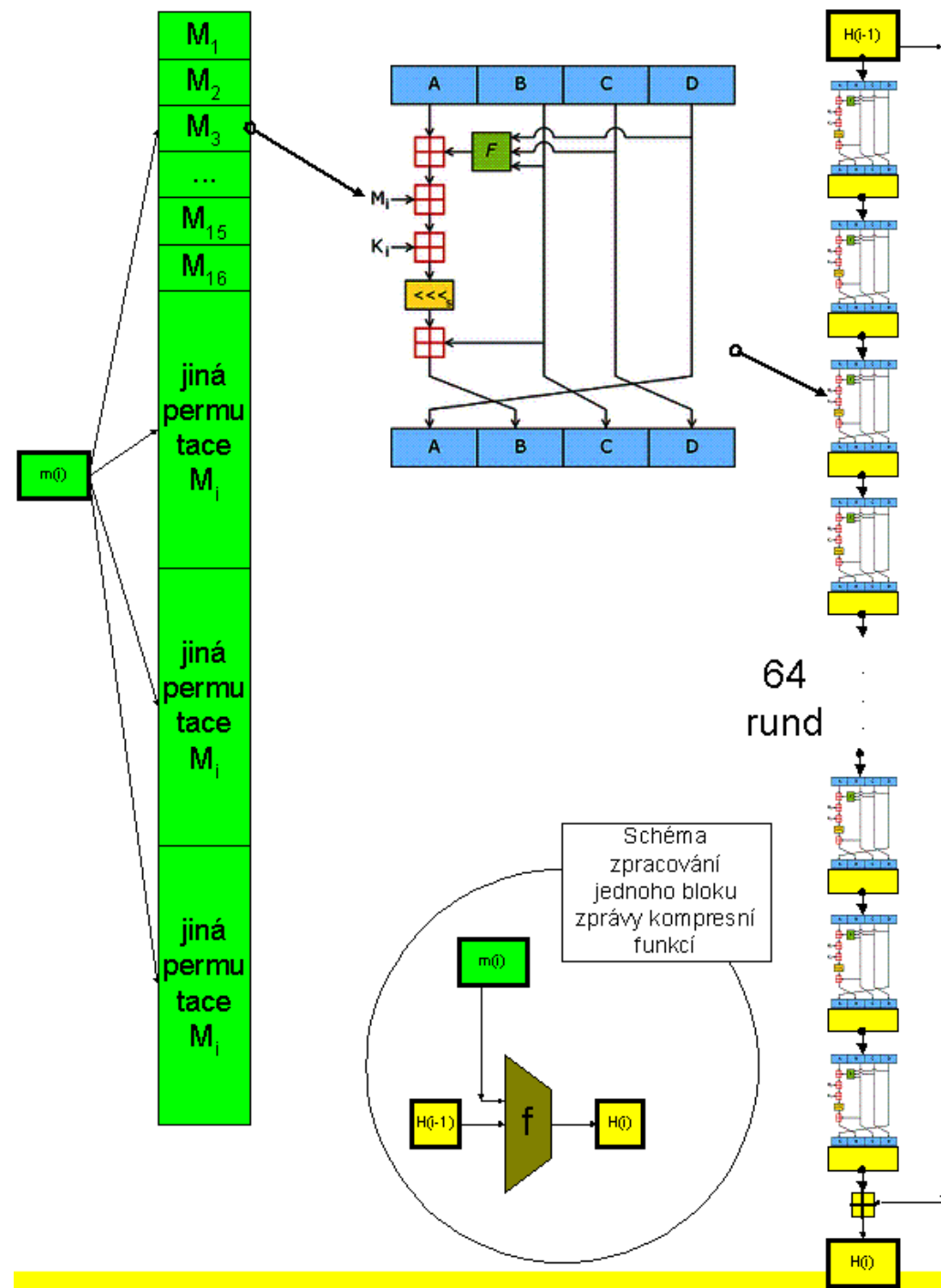
16 kol (4 x 4)

4 varianty funkce $F(x,y,z) =$

- $(x \wedge y) \vee (\neg x \wedge z)$
- $(x \wedge z) \vee (y \wedge \neg z)$
- $(x \oplus y \oplus z)$
- $y \oplus (x \vee \neg z)$



Jedna runda hashování



- Jeden 512 bitový blok zprávy m_i je rozdělen na 16 32bitových slov $M_0, M_1, \dots, M_{15}$, a tato posloupnost je opakována 4x za sebou (v různých permutacích).
- V kompresní funkci se kontext "zašifruje" vždy jedním 32bitovým slovem M_i .
- Na místě dílčí funkce F v obrázku se po 16 rundách střídají 4 různé (nelineární i lineární) funkce (F, G, H, I) a v každé rundě se využívá jiná konstanta K_i .
- Po 64 rundách dojde ještě k přičtení původního kontextu (H_{i-1}) k výsledku podle Davies-Meyerovy konstrukce (xor je nahrazen aritmetickým součtem modulo 2^{32}).
- Tak vznikne nový kontext H_i .
- Pokud by zpráva M měla jen jeden blok, byl by kontext (A, B, C, D) celkovým výsledkem. Pokud ne, pokračuje se stejným způsobem v hašování druhého bloku zprávy m_2 jakoby s inicializační hodnotou H_{i-1} . Po zpracování bloku m_N máme v registrech výslednou 128bitovou haš H_N .

MD5

1. Krok: Doplnění zprávy (1000...) na délku, která je o 64 bitů menší než nejbližší celý násobek 512
$$\text{Délka(zpráva)} \bmod 512 = 448$$
2. Krok: Délka původní zprávy se jako 64-bitové číslo připojí k výstupu z 1.kroku (doplní se na násobek 512)
3. Krok: Inicializace čtyř 32-bitových registrů
 1. A: 01 23 45 67
 2. B: 89 ab cd ef
 3. C: fe dc ba 98
 4. D: 76 54 32 10
4. Krok: Každý blok (512b) se zpracuje ve 4 cyklech, kterých se dále účastní:
 - 4 pomocné funkce
 1. $F(X, Y, Z) = XY \vee \text{not}(X) \wedge Z$
 2. $G(X, Y, Z) = XZ \vee Y \wedge \text{not}(Z)$
 3. $H(X, Y, Z) = X \oplus Y \oplus Z$
 4. $I(X, Y, Z) = Y \oplus (X \vee \text{not}(Z))$
 - Konstanty T odvozené z fce $\sin(x)$

HASH použití

- Uložení hesel
- Kontrolní součty (bez šifrování)
- Kontrola integrity – klíčované kontrolní součty (HMAC)
- Výtah (otisk) zpráv pro digitální podpis
- Výtah (otisk) klíčů
- MD5: 128b, SHA-1: 160b
- SHA-256, SHA-512 – zvýšení bezpečnosti

Elektronický (digitální)
podpis

Elektronický (digitální) podpis

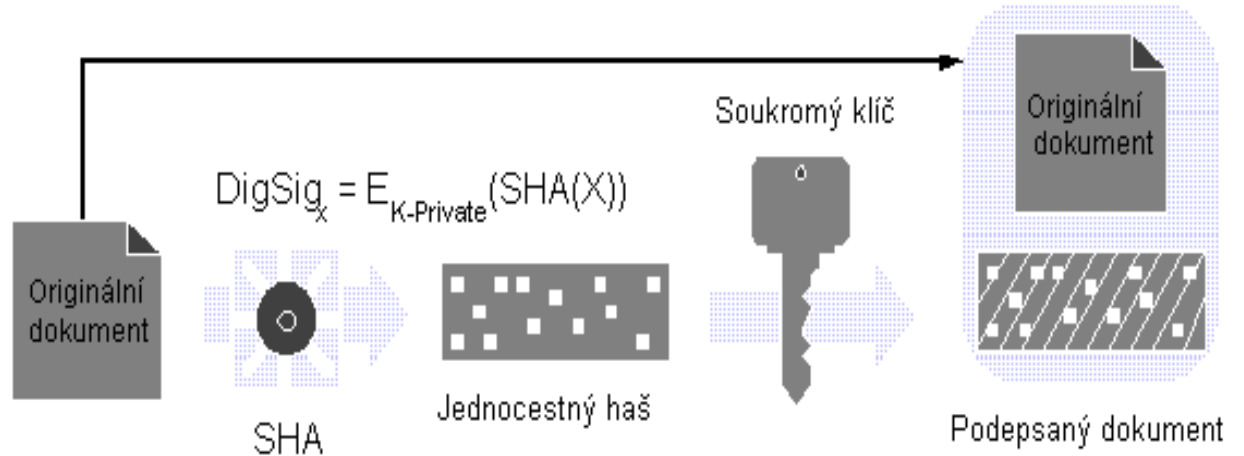
- Odesílatel

- d – soukromý klíč
- M – zpráva
- $H = \text{HASH}(M)$
- $S = (H)^d \bmod N$
- $M + S$ – digitálně podepsaná zpráva

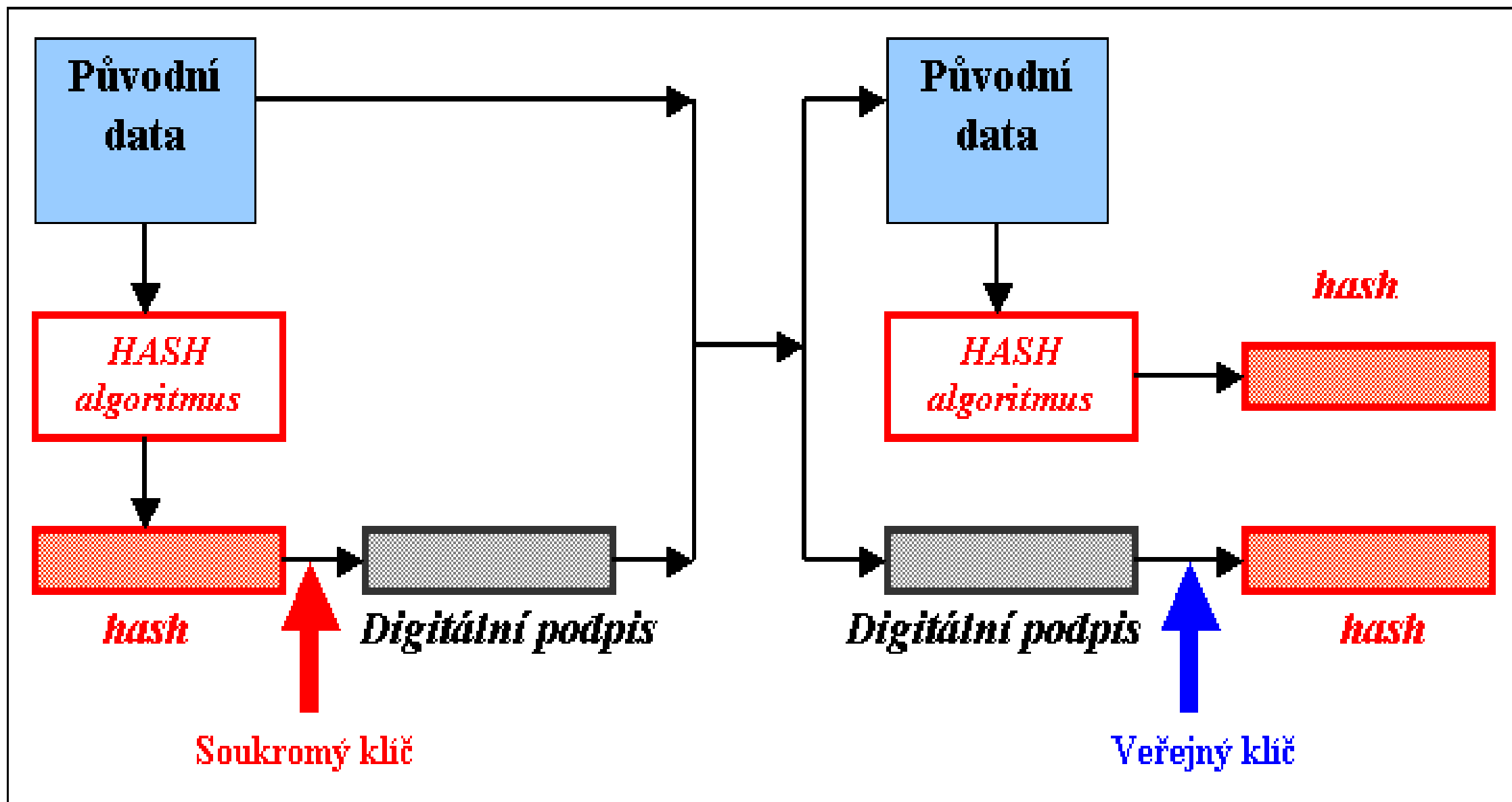
- Příjemce

- $\{e, N\}$ – veřejný klíč odesílatele
- Z připojeného podpisu – $H_1 = S^e \bmod N$
- Z vlastní zprávy – $H_2 = \text{HASH}(M)$

- $H_1 = H_2$



Princip digitálního podpisu



K čemu je elektronický podpis

Elektronický podpis slouží k **zajištění ověření autora** a **integrity podepisovaných dat**.

Elektronický podpis je podpis – tj. pouze jiná forma písemného podpisu. Stejně jako písemným podpisem, potvrzujeme, že jsme nějaký text vytvořili a bereme za něho odpovědnost.

ČR: [Zákon č. 227/2000 Sb., o elektronickém podpisu](#)

Elektronický podpis

- Elektronický podpis zabezpečuje
 - integritu podepsané zprávy (nezfalšovatelnost)
 - autentičnost podepsané zprávy (potvrzení původnosti dokumentu a totožnosti autora)
 - nepopiratelnost podepsané zprávy (lze dokázat zodpovědnost podepsaného subjektu- odesílatel nemůže prohlásit, že dokument nepodepsal)
 - Jednorázové použití – konkrétní podpis nelze použít pro jiný dokument
- Kryptografické složky zajišťující digitální podpis – [FIPS 186](#)
 - asymetrické kryptografické systémy
 - hash funkce
 - správa veřejných klíčů – PKI (Public Key Infrastructure)
 - certifikát veřejného klíče – certifikační autorita (CA)

Definice el. podpisu

Zaručený elektronický podpis

1. je jednoznačně spojen s podepisující osobou,
2. umožňuje identifikaci podepisující osoby ve vztahu k datové zprávě,
3. byl vytvořen a připojen k datové zprávě pomocí prostředků, které podepisující osoba může udržet pod svou výhradní kontrolou,
4. k datové zprávě, ke které se vztahuje, je připojen takovým způsobem, že je možné zjistit jakoukoliv následnou změnu dat.

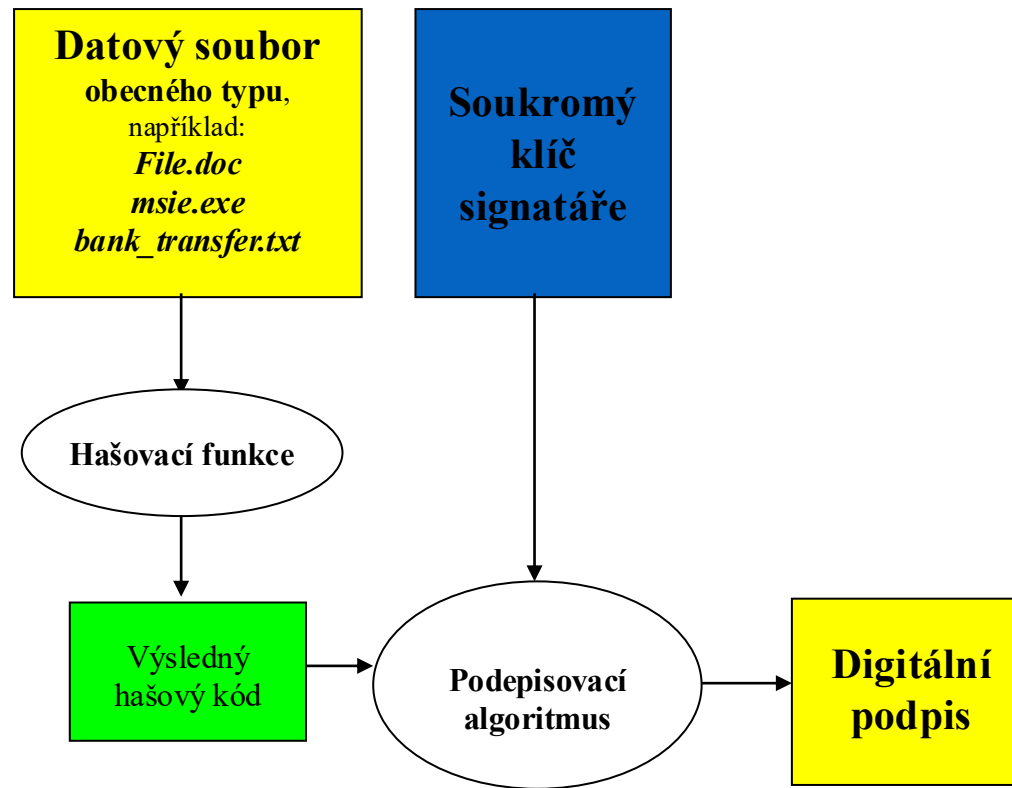
Uznávaný elektronický podpis

zaručený elektronický podpis + kvalifikovaný certifikát vydaný akreditovaným poskytovatelem certifikačních služeb

Mechanismus elektronického podpisu

- Zpráva, kterou chceme podepsat
- Hash funkce vypočítá „hash“ zprávy (neboli otisk, digest)
- Otisk je zašifrován pomocí „soukromého klíče“ a přidán ke zprávě
- Na straně příjemce – otisk se dešifruje „veřejným“ klíčem, pomocí hash funkce se vytvoří nový otisk
- Srovnání obou otisků = ověření, zda podpis je platný a zda zpráva je nezměněná

Podepsání zprávy el. podpisem



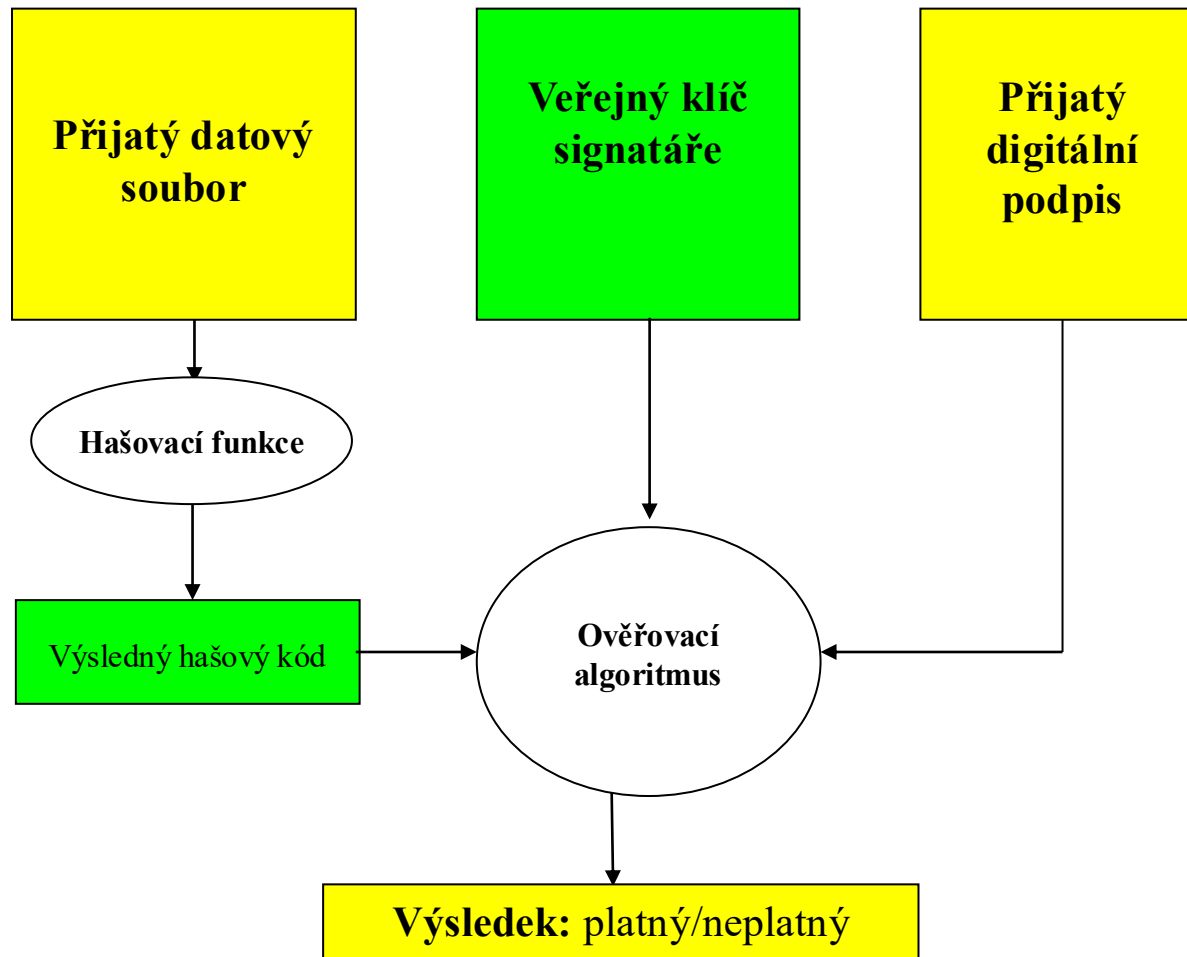
Hash funkce

Není podepisována samotná datová zpráva, ale zpráva je nejdříve převedena pomocí kryptografické *hash funkce* do tvaru **kontrolního vzorku** (*digest*) a ten je následně podepsán.

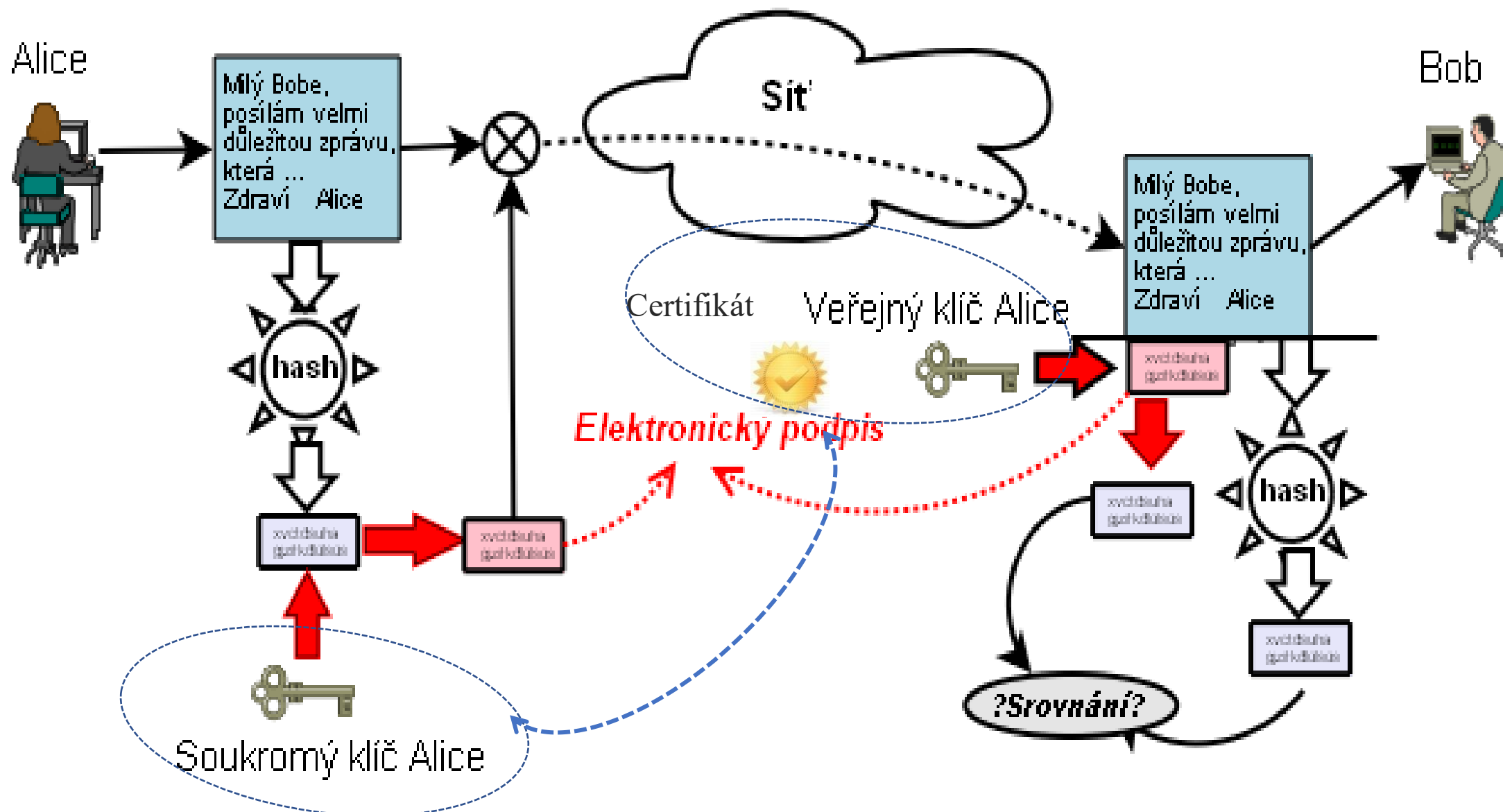
Použitá hash funkce musí zaručovat následující požadavky:

- Zpráva na vstupu hash funkce má vždy stejnou hodnotu kontrolního vzorku;
- Nelze provést, aby z výstupního kontrolního vzorku byl zjištěn tvar datové zprávy, ze které byl kontrolní vzorek pomocí hash funkce získán;
- Nelze zajistit, aby dvě různé datové zprávy na vstupu hash funkce vedly ke stejnému kontrolnímu vzorku.

Přijetí zprávy s el. podpisem



Elektronický podpis



Elektronický a ruční podpis

Ruční podpis je výsledkem cílevědomé činnosti osoby, která se podepisuje a využívá přitom svých individuálních vlastností a schopností.

Naproti tomu je elektronický podpis řetězec dat, který je příslušným *SW* (např. v *PC*) připojen s využitím kryptografických metod k datové zprávě a je vytvořen na základě vstupních dat, které zná pouze podepisující se osoba.

BEZPEČNOST elektr. podpisu

Bezpečnost el.podpisu je postavena na tom, aby:

- Nemohlo dojít k narušení tajnosti privátního klíče.
- Nebyl prolomen použitý kryptoalgoritmus ani narušena kryptologická bezpečnost hash funkce.
- Nedošlo k porušení autentičnosti veřejného klíče a tím nedodržení záruky, že deklarovaný veřejný klíč přísluší osobě, která zprávu podepisovala.

Aby byla splněna třetí bezpečnostní podmínka, je v prostředí s velkým počtem uživatelů využíván systém certifikátů poskytovaných nezávislou třetí stranou - ***certifikační autoritou*** (poskytovatelem certifikačních služeb).

Certifikáty a certifikační authority

Problém el. podpisu – záruka, že nabízený veřejný klíč, kterým dojde k ověření informací, skutečně náleží osobě, které jsou informace určeny.

Aby k záměně klíčů nedošlo, byly ustanoveny tzv. **certifikační authority** = důvěryhodné třetí strany, které pomocí **certifikátu zaručují, že veřejný klíč patří opravdu tomu, kdo je označen jako jeho vlastník.**

Certifikáty

- Certifikáty
 - Obyčejné
 - Klasifikované (vydává akreditovaný poskytovatel certifikačních služeb)
- Certifikát obsahuje:
 - Jméno a veřejný klíč majitele
 - Doba vypršení platnosti
 - Jméno certifikační autority
 - Digitální podpis vydavatele certifikátu (kterým certifikační autorita ručí, že certifikát je v pořádku)

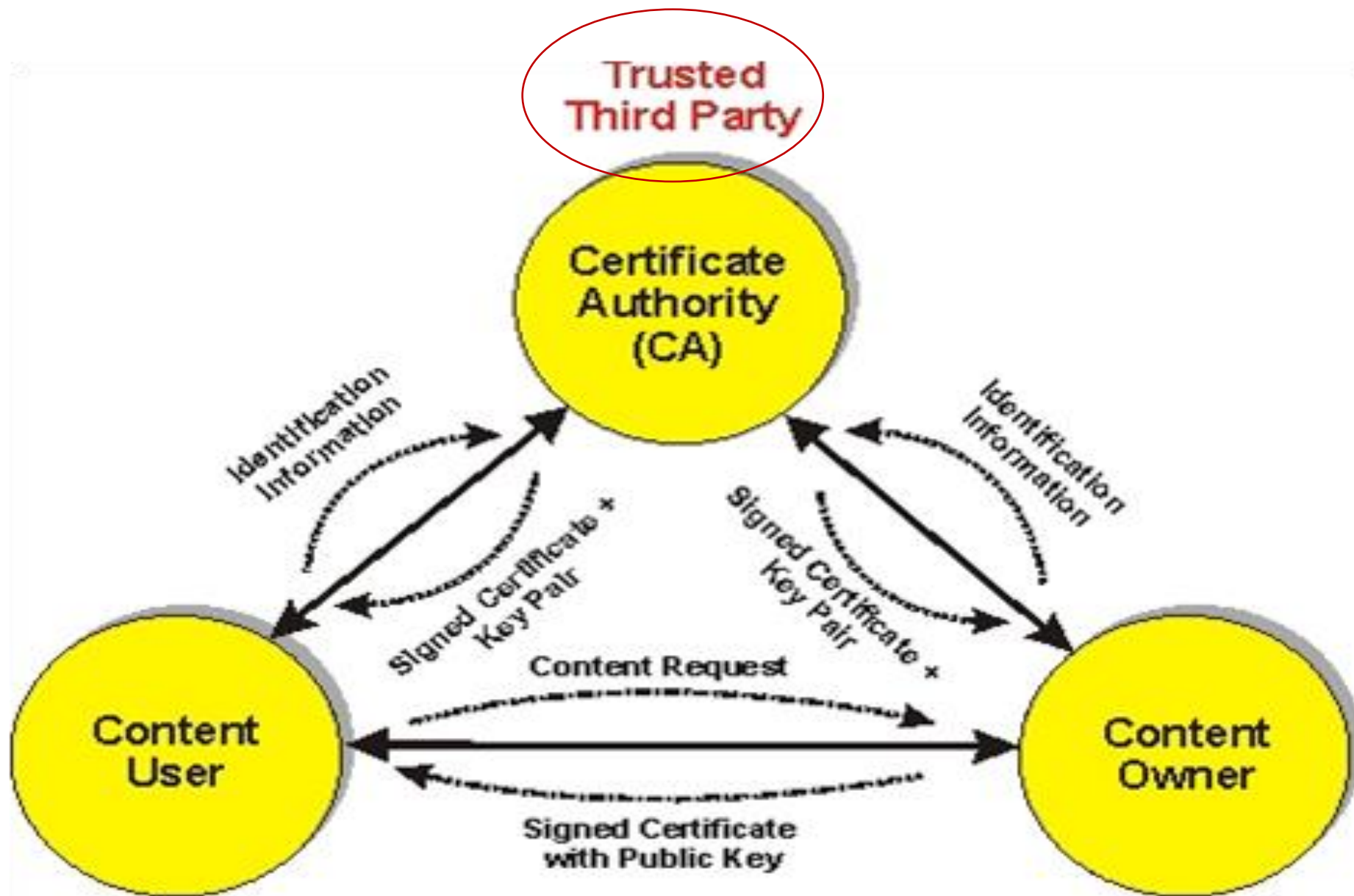
Důvěryhodnost elektronického podpisu

- Důvěryhodnost DP na principu asymetrického kryptografického systému s veřejným klíčem je podmíněna **silným autentizačním mechanismem**
- Jednoznačné spojení podepisujícího subjektu s veřejným klíčem, o kterém prohlašuje, že je jeho vlastníkem
- Řešení – autenticitu VK ověřuje nezávislá třetí strana – **certifikační autorita (CA)**
- CA je důvěryhodná infrastruktura pod správou důvěryhodného provozovatele, který svým kreditem a certifikační politikou poskytuje dostatečnou bezpečnostní a funkční záruku
- **Elektronický certifikát** – datová struktura obsahující kromě veřejného klíče údaje o vlastníkově veřejného klíče a o CA, která certifikát vydala

PKI

- Automatizovanou správou veřejných klíčů zajišťuje **PKI (Public Key Infrastructure)**
- PKI se opírá se o řadu standardů a doporučení sjednocujících přístupy různých poskytovatelů těchto služeb
 - zákonná opatření a obecné normy informační bezpečnosti
 - ISO/IEC 9594-8:1999 /ITU-T X.509 – formát certifikátu
 - LDAP/ X.500 (Lightweight Directory Access Protocol) - podpora správy úložišť klíčů a certifikátů platných i zbavených platnosti
 - PKCS #6 – formát rozšířeného certifikátu
 - PKCS #10 – syntaxe žádosti o certifikát
 - ISO/IEC 11770-1 až 3 – správa klíčů

Princip certifikace veřejného klíče

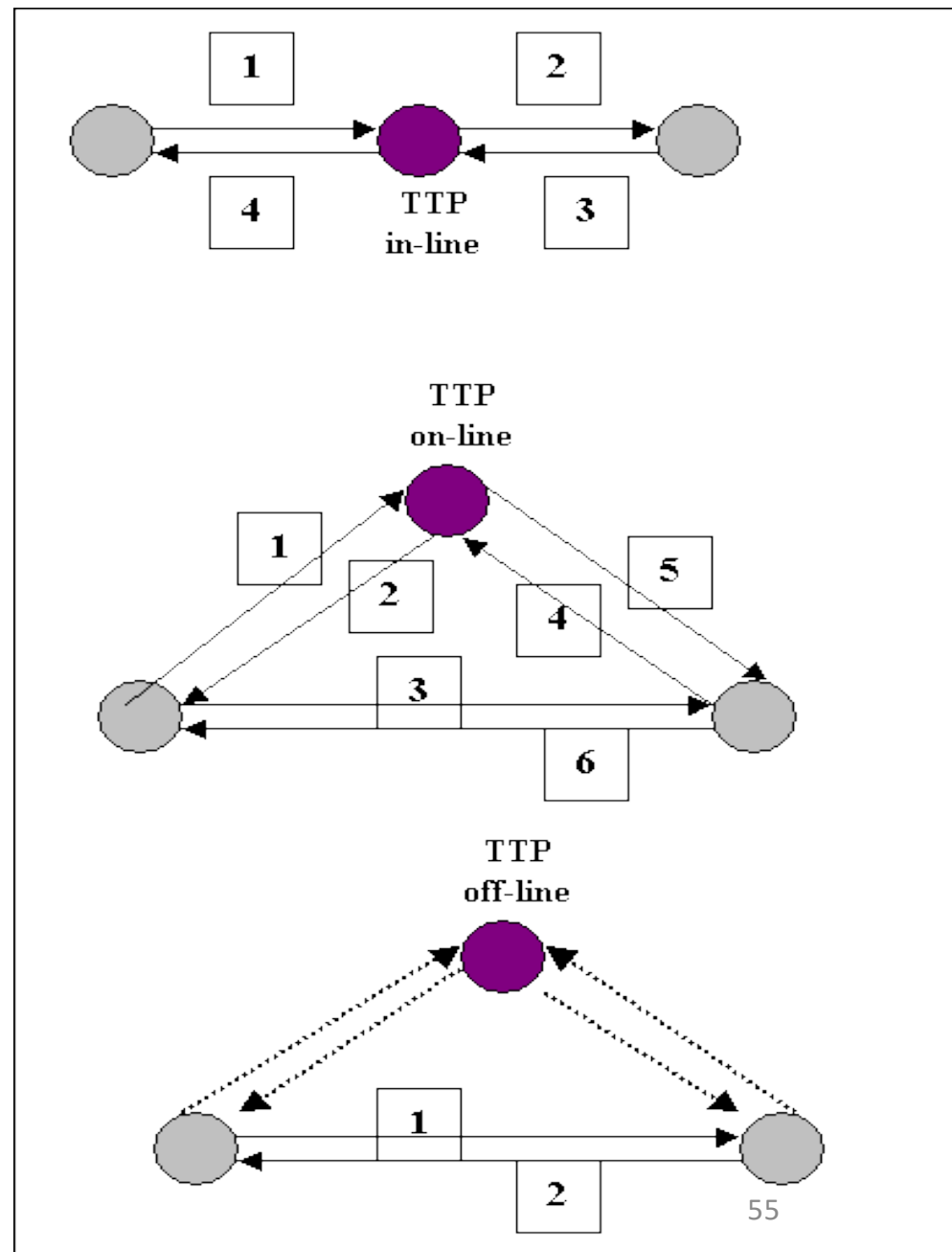


TTP (Trusted Third Party) v kybernetické bezpečnosti

- TTP je bezpečnostní autorita nebo její agent, který je důvěryhodný pro všechny ostatní entity zapojené do zabezpečené transakce. Všechny zúčastněné strany toto odsouhlasí při zahájení transakce
- Požadavky na služby TTP
 - TTP provádí činnosti v právním rámci
 - TTP musí být pod dohledem dozorového orgánu
 - TTP musí dodržovat vlastní odpovídající bezpečnostní politiku
 - TTP má mít akreditaci kvality procesů a operací
 - TTP musí poskytovat záruky za dostupnost a kvalitu svých služeb

Režimy činnosti TTP

- In-line TTP působí uprostřed transakčního kanálu mezi komunikujícími entitami jako proxy agent
- On-line TTP je dostupný během transakce pro real time interakci, ale entity mohou spolu komunikovat i nezávisle
- Off-line TTP nemusí být stále k dispozici během trvání transakce, požadavky na jeho služby se řadí do fronty a plní se v následujících cyklech



Získ certifikátu

Certifikát se vydává na základě žádosti

1. Krok: Generování klíčů

- Žadatel (ne CA) vygeneruje dvojici veřejný a soukromý klíč.

2. Krok: Výběr CA

3. Krok: Zadání požadovaných informací

- Žadatel zadá informace nutné k vydání certifikátu – č. OP, DIČ, e-mailová adresa, ...
- Předání veřejného klíče a požadovaných informací CA (často zašifrovaně pomocí veřejného klíče CA).

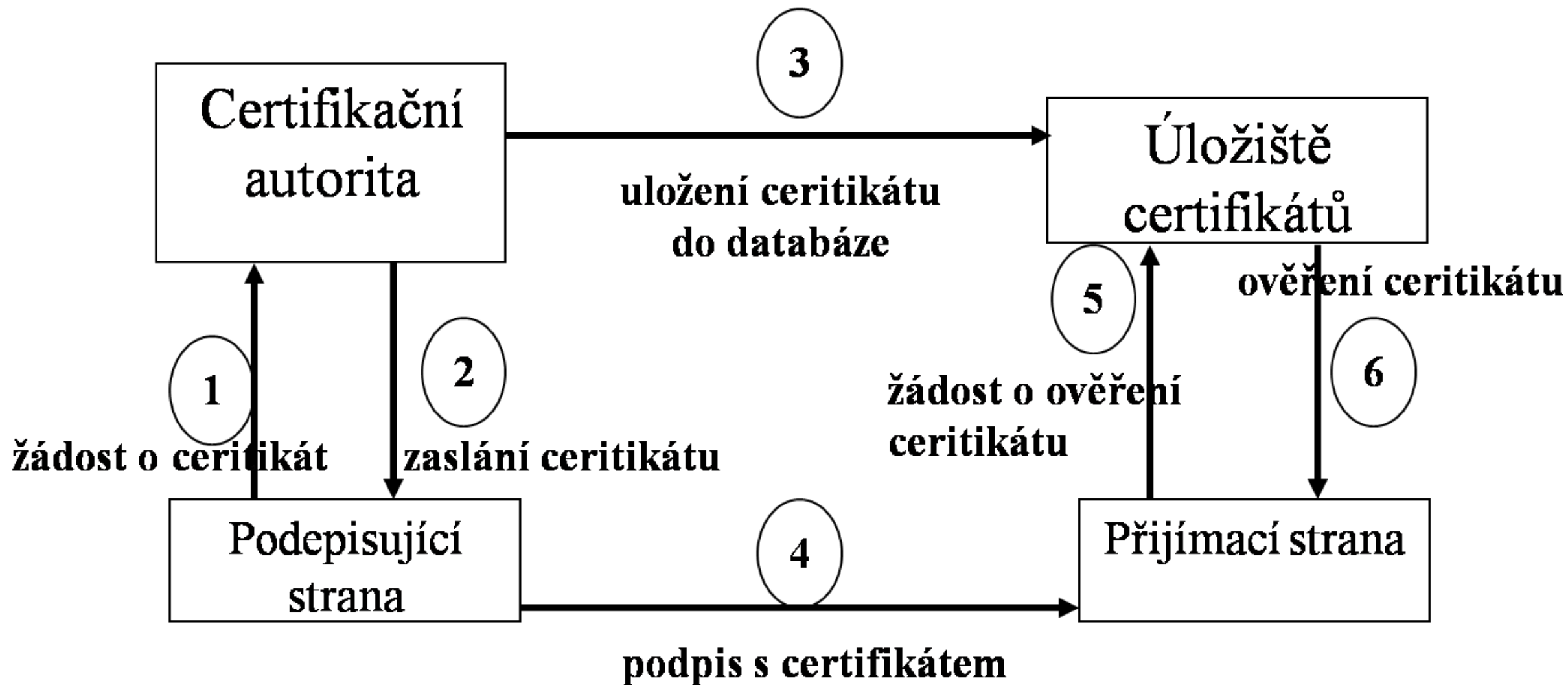
4. Krok: CA ověří informace

5. Krok: CA vytvoří certifikát

- vytvořený digitální dokument CA podepíše soukromým klíčem.

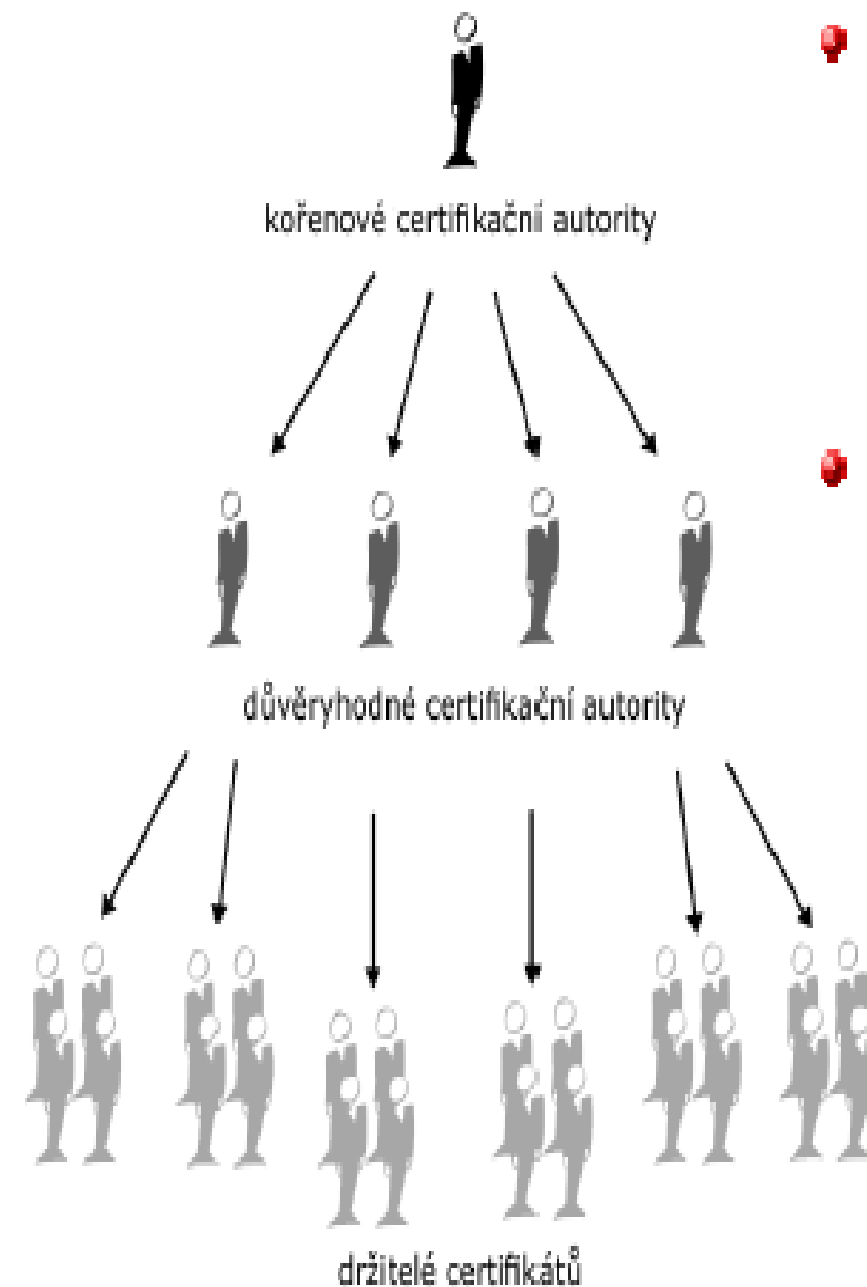
6. Krok: CA předá certifikát žadateli

Postup certifikace veřejného klíče



Hierarchie CA

- Problém – jak zveřejnit veřejný klíč CA
- Řešeno prostřednictvím hierarchie CA
- Nejvyšší úroveň – kořenové CA
- CA z vyšší úrovně certifikují CA na nižší
- Tranzitivita důvěry
 - Vzájemným nastavením důvěry (ověření) mezi CA lze nastavit důvěru ke všem certifikátům vydaným ověřenou CA

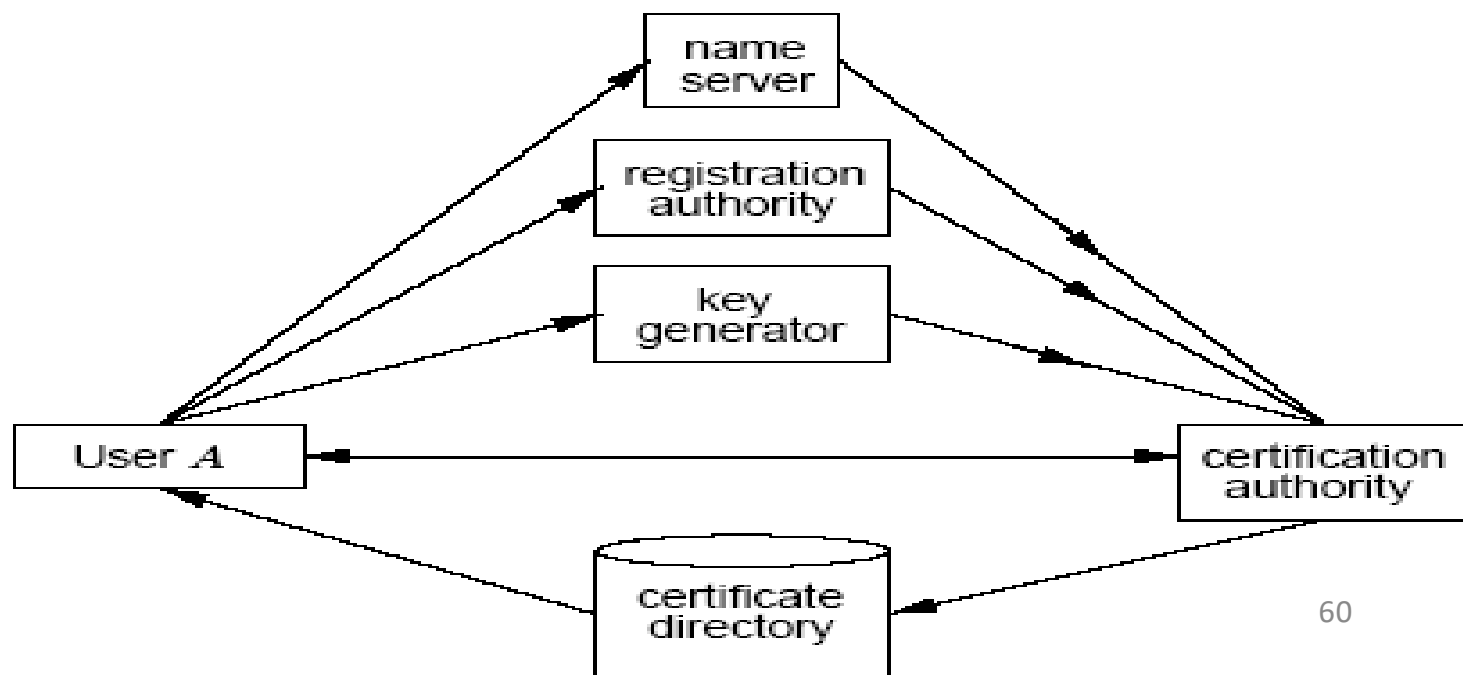


Funkce CA

- registrace uživatelů certifikátů
- vydávání certifikátů k veřejným klíčům
- odvolávání platnosti certifikátů
- vytváření a zveřejňování seznamu certifikátů
- odebírání platnosti certifikátům
- zveřejňování zneplatněných certifikátů v seznamu **CRL** (Certificate Revocation List)
- správa klíčů po dobu jejich platnosti (životního cyklu)
- dodatkové služby – např. poskytování časových známek (time-stamping)

Registrační autorita (RA)

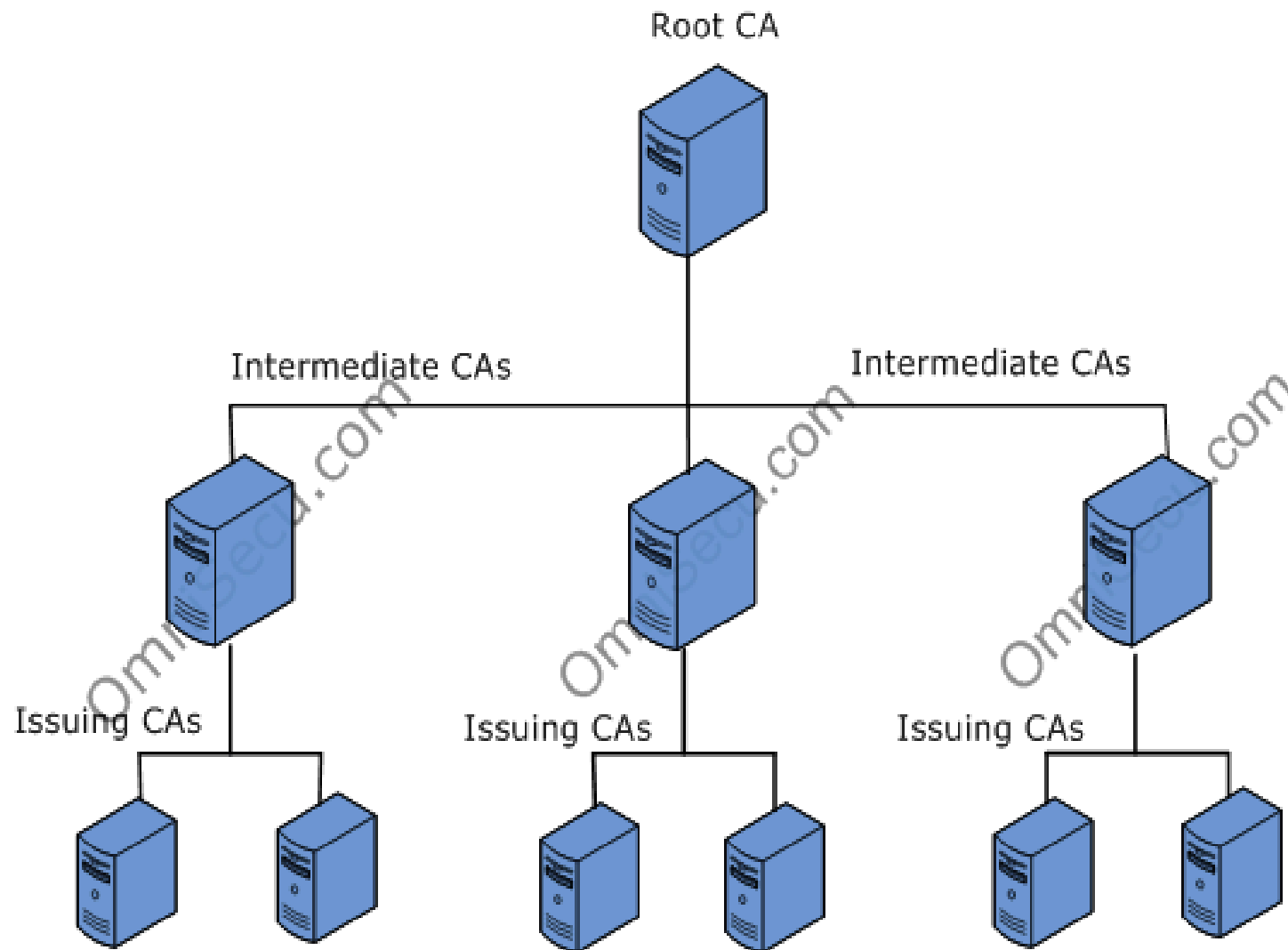
- Nepovinná složka PKI
- Vytváří vazbu mezi klientem a CA v souladu s CPS (Certification Practice Statement)
 - přijímá žádosti o certifikace
 - ověřuje pravdivost uvedených údajů
 - předává certifikát CA k podpisu
 - podepsaný certifikát předá klientovi



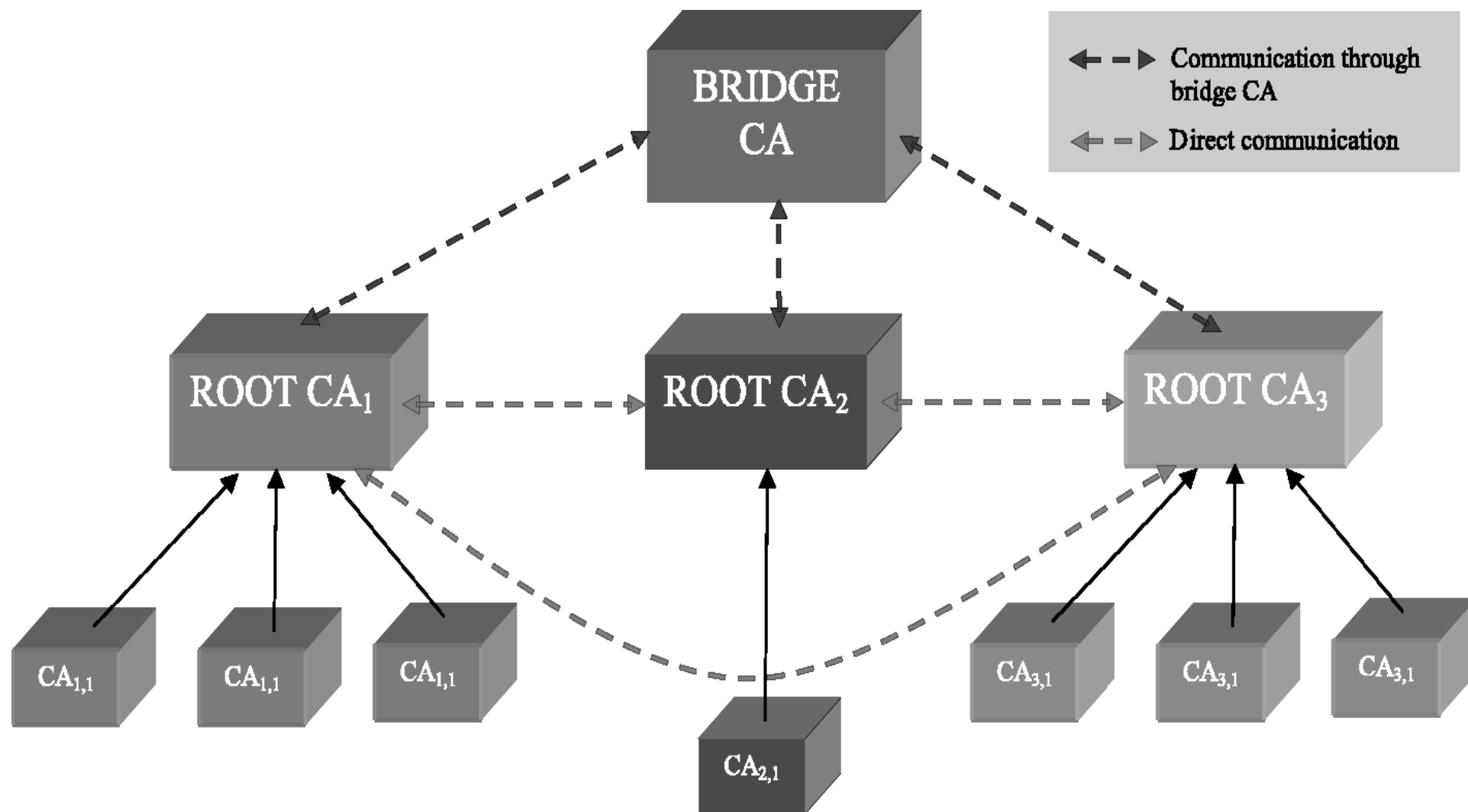
Hierarchie CA

- Problém - vzájemné ověření certifikátů, které jsou vydány různými CA.
- Cíl – vytvoření jediné struktury CA s kořenovou (globální) CA
- Řešení - vzájemné propojení CA
 - Kořenová hierarchie CA - primární CA pro vydávání certifikátů podřízeným CA
 - Křížové ověření CA (tzv. mesh PKI architektura) - na úrovni kořenových CA nebo primárních CA
 - Ověření CA přes brány - při nekompatibilních implementacích CA

Hierarchie CA s kořenovou CA

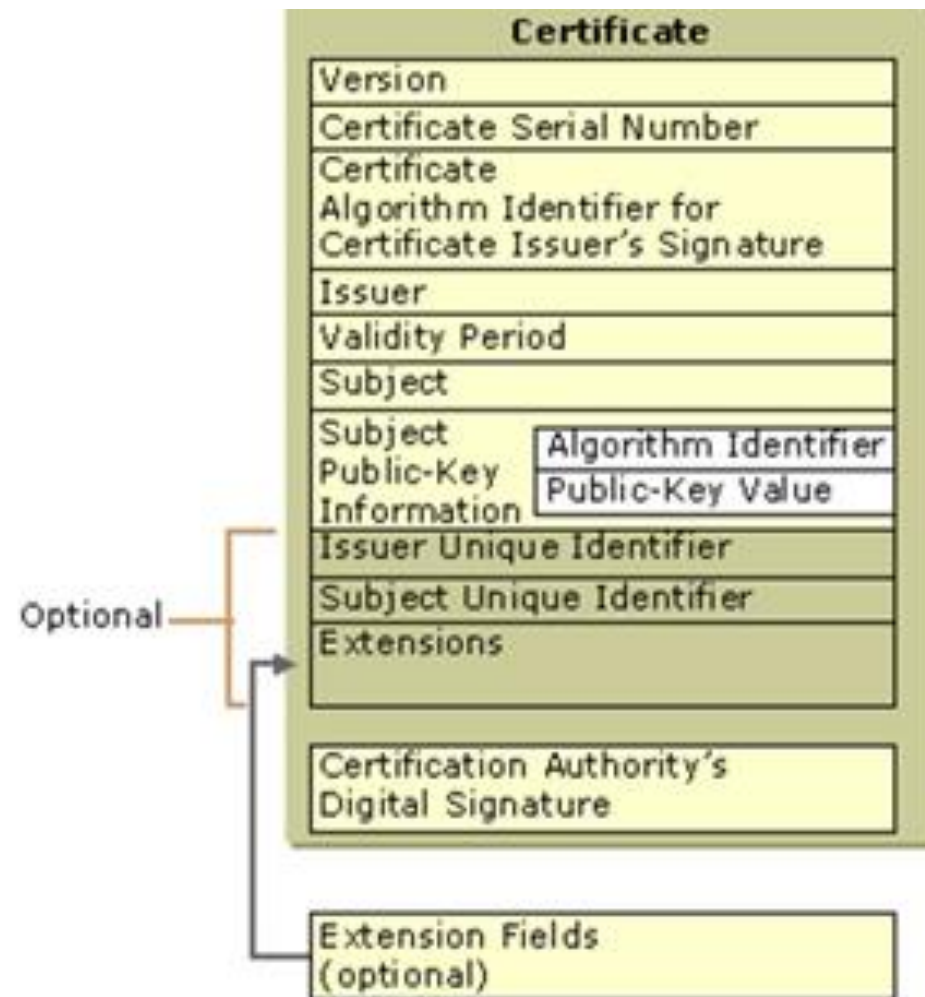


Hierarchie CA s více kořenovými CA



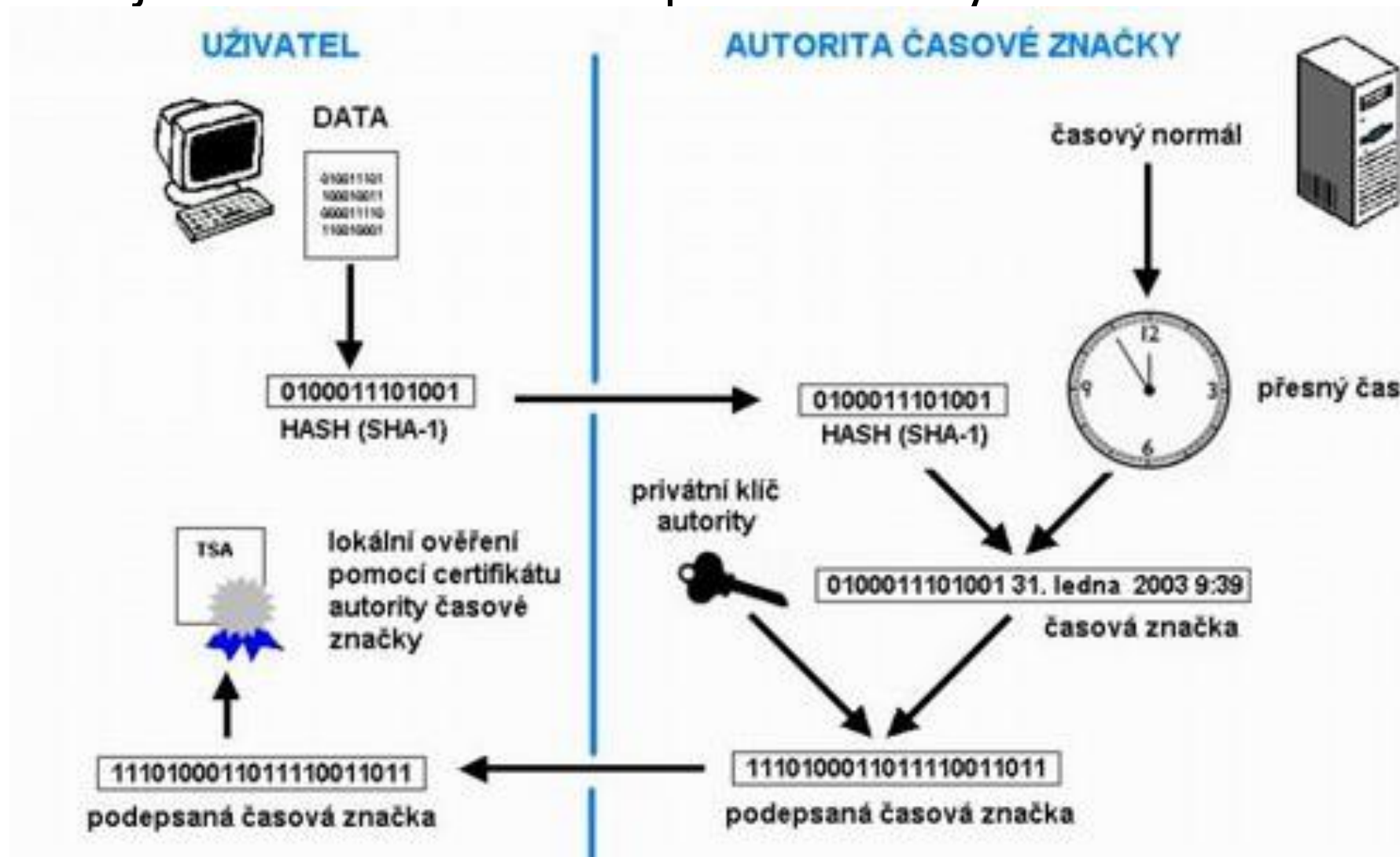
Certifikát veřejného klíče

- **Formát certifikátu** je popsán normou RFC2459 a doporučením **ITU X.509**
- **Certifikát je datová struktura** popsaná v jazyce ASN.1 a pro přenos je kódovaná podle specifikace DER (Distinguished Encoding Rules).
- **Obsah certifikátu**
 - Jméno vlastníka certifikátu
 - Sériové číslo certifikátu
 - Doba platnosti certifikátu
 - Algoritmus veřejného klíče
 - Kopie veřejného klíče vlastníka certifikátu
 - Jméno CA
 - Digitální podpis CA



TSA – časové razítko

- Time Stamping Authority
- Časové razítko stvrzuje existenci informace před uvedeným časem



Poznámky na závěr

K zajištění důvěrnosti a neodmítnutelnosti odesílané zprávy je nutné

- Obsah zprávy zašifrovat náhodně vygenerovaným symetrický klíčem, který se následně zašifruje veřejným klíčem příjemce, tím je zajištěno, že jen on dokáže její obsah dešifrovat.
- Hash zprávy se pak zašifruje privátním klíčem odesílatele, protože pomocí veřejného klíče odesílatele si pak příjemce může ověřit, že zprávu opravdu odeslal daný odesílatel.

Při použití asymetrické kryptografie je nejdůležitější

- Aby měl podepisující subjekt zařízení, na kterém probíhá podepisování plně pod kontrolou.
- Pokud jde o podpis a zajištění neodmítnutelnosti, tak by měl mít podepisující subjekt dané zařízení pod svou výhradní kontrolu.

Webová stránka opatřená certifikátem a ikonkou záměčku značí

- Že komunikace s webem je šifrovaná
- To, že je web opatřen certifikátem a ikonkou záměčku, znamená jediné, a to že je komunikace šifrována, ale nikoliv, zda je použita bezpečná šifra. A může se zde rovněž nacházet malware, anebo se může jednat o podvodný web.

Steganografie

- zastírá skutečnost, že je přenášena tajná zpráva.
- Cílem steganografie je zakrýt skutečnost, že je vůbec přenášena nějaká tajná zpráva v rámci jiné, může tak být ukryta v nevinně vypadajícím textu, obrázku, hudbě anebo i ve videu.

Další příklady na RSA

Příklad generování RSA

- Vezmeme za **p, q** prvočísla **5, 11**. Dostaneme **$n=5*11=55$** a **$f(n)=4*10=40$** .
- Za šifrovací klíč můžeme volit čísla mezi **1-39** nesoudělná s **$f(n)=40$** . Zvolíme tedy např. **$e=17$** a najdeme k němu multiplikativní inverzi modulo 40:
- tak aby platilo $de \equiv 1 \pmod{40}$
- $d \cdot 17 \equiv 1 \pmod{40}$, - hledáme d kdy $x \cdot 40 + y \cdot 17 = 1$
- $40 = 2 \cdot 17 + 6$ takže $6 = 40 - 2 \cdot 17$
- $17 = 2 \cdot 6 + 5$ takže $5 = 17 - 2 \cdot 6 = 17 - 2(40 - 2 \cdot 17)$
- $6 = 1 \cdot 5 + 1$ takže $1 = 6 - 5$ dosazením $1 = (40 - 2 \cdot 7) - (17 - 2(40 - 2 \cdot 17)) = 40 - 2 \cdot 7 - 17 + 2 \cdot 40 - 4 \cdot 17 = 3 \cdot 40 - 7 \cdot 17$ takže $d = 40 - 7 = 33$ (protože je $-7 \cdot 17$ musí se dopočítat modulo)
- $d=33$
- Veřejný klíč $e=17$, $n=55$, Tajný klíč $d=33$, $n=55$
- Necht' nyní zpráva (může být mezi **1-54**) je **$m=14$** , zakódujeme ji na **$14^{17} \pmod{55} = 30$** **491 346 729 331 195 904 $\pmod{55} = 9$** .
- Dekódování pak proběhne podobně: **$9^{33} \pmod{55} = 309$ 031 543 826 326 123 611 920 641 803 529 $\pmod{55} = 14$** .

Příklad generování RSA

- Nalezneme dvě prvočísla $p = 17$ a $q = 11$.
- Jejich součin označíme $n=p*q = 187$.
- Nyní zvolíme číslo $e = 7$.
- Číslo e a $(p-1) * (q-1) = 16 * 10 = 160$ nesmí mít společného dělitele – což nemají
- Zveřejníme veřejný klíč n a e tj, **187** a **7**
- Výpočet dešifrovacího klíče tak aby $de \equiv 1 \pmod{160}$
- $d \cdot 7 \equiv 1 \pmod{160}$, - hledáme d kdy $x \cdot 160 + y \cdot 7 = 1$
- $160 = 22 \cdot 7 + 6$ takže $6 = 160 - 22 \cdot 7$
- $7 = 6 + 1$ takže $1 = 7 - 6 = 7 - 160 + 22 \cdot 7 = -160 + 23 \cdot 7$
- $d=23$
- Chceme poslat zprávu **M=88**
- Vypočte **$C=88^7 \pmod{187} = 11$** a odešle **C** tj. **11**
- Rozluštění **$M=C^d \pmod{187} = 11^{23} \pmod{187} = 88$**

Problém výpočtu velkých mocnin na kalkulačce

- Máme vypočíst **$C=88^7(\text{mod } 187)$**
- **$7=4+2+1$**
- Pak **$88^7(\text{mod } 187)=[88^4(\text{mod } 187) \cdot 88^2(\text{mod } 187) \cdot 88^1(\text{mod } 187)](\text{mod } 187)$**
- **$88^1=88(\text{mod } 187)$**
- **$88^2=7744=77(\text{mod } 187)$**
- **$88^4=59969536=132(\text{mod } 187)$**
- **$88^7=88^1 \cdot 88^2 \cdot 88^4=894432=11(\text{mod } 187)$**